INSTITUTO SUPERIOR TÉCNICO
Universidade Técnica de Lisboa

Maturidade da Gestão Informática na Administração Pública Portuguesa

João Filipe da Silva Carracha

Dissertação para obtenção do Grau de Mestre em

Engenharia Informática e de Computadores

Júri

Presidente:	Professor Doutor José Tribolet
Vogal:	Professor Doutor Alberto Silva
Orientador:	Professor Doutor André Vasconcelos
Co-Orientador:	Professor Doutor Miguel Mira da Silva

Outubro de 2010

Agradecimentos

Gostaria de expressar nesta secção os agradecimentos a todos os intervenientes que tornaram possível a concretização desta investigação.

Gostaria de agradecer particularmente:

- Às instituições e empresas intervenientes nesta investigação por todo o apoio e tempo dispendidos.
- À Agência para a Modernização Administrativa – AMA por todo o suporte e informações concedidas.
- Aos Professores Miguel Mira da Silva e André Vasconcelos por todos os conselhos sábios e críticas construtivas.
- À minha família e namorada, Joana, pelo apoio incondicional ao longo deste meu percurso.
- Ao Nuno Castro e alunos de OGFI pelas revisões e trocas de ideias que enriqueceram o trabalho.

Resumo

O processo de modernização administrativa surgiu, na presente década, como uma causa maior motivada por *drivers* externos resultantes de um consenso gerado a nível da União Europeia. Um dos objectivos a que Portugal se propôs cumprir foi a redução de custos associados às Tecnologias de Informação (TI). No entanto, a descentralização da função informática e consequente criação de múltiplos departamentos informáticos (DI) de pequena e média dimensão constituem entraves à consumação da referida meta.

Durante a presente investigação foram auditados três DI na APP de dimensões pequena, média e grande, usando a *framework* CobiT 4.1. Os DI de diferentes dimensões foram escolhidos tendo em conta a sua representação mediana no tamanho que possuem. Ou seja, o DI de pequena dimensão, por exemplo, representa a média daquilo que é o universo total deste tipo de DI na APP.

Sabendo que as classificações de maturidade CobiT estão directamente relacionadas com a qualidade dos DI pretende-se, através dos resultados obtidos, avaliar a qualidade da função informática existente na APP e validar a hipótese de que a qualidade dos DI e respectivos serviços aumenta com a sua dimensão, ou seja, o foco principal deste problema reside nos DI de pequena dimensão, pois têm dificuldades em atingir economias de escala.

As auditorias realizadas e os resultados obtidos validam a hipótese mencionada anteriormente, o DI de pequena dimensão obteve uma classificação de 0 na escala de 0 a 5, enquanto os DI de dimensão média e grande obtiveram respectivamente 2 e 3.

Palavras Chave

Organização e gestão da função informática, Administração Pública, Níveis de Maturidade, Custos, Auditoria, Qualidade dos Serviços.

Abstract

The process of administrative modernization emerged in this decade as a major cause driven by external drivers originated from a consensus within the European Union. One of the goals to which Portugal has offered to meet was the reduction of costs related to Information Technology (IT).

However, the decentralization of IT function and the consequent creation of multiple small and medium IT departments (ITD) hinder the accomplishment of that goal.

During this investigation were audited three ITD in the Portuguese Public Administration (PPA) with small, medium and large sizes, using the COBIT 4.1 *framework*. All the three ITD were chosen in view of their representation in the median size they have. That is, for example, the small IT department represents the average of what is the total universe of this type of IT departments in the PPA.

Knowing that ratings of CobiT maturity are directly related to the IT department quality we intend to evaluate, through the results, the quality of existing information technology function in PPA and further validate the hypothesis that the quality of the ITD and the services rendered by them increases with their size, i.e., the main focus of this problem lies in the small ITD, because they lack economies of scale.

The audits performed and the results obtained validate the hypothesis mentioned previously, the small IT department got a rating of 0 in the range 0-5, while the medium and large obtained respectively 2 and 3.

Keywords

IT Management and Organization, Public Administration, Maturity Levels, Costs, Auditing, Service Quality.

Índice

Agradecimentos ____ i

Resumo ____ ii

Abstract ____ iii

Lista de Figuras ____ viii

Lista de Tabelas ____ ix

Lista de Acrónimos ____ x

1 Introdução ____ 1

1.1 Enquadramento ____ 1

1.2 Definição do Problema ____ 2

1.3 Contribuições ____ **Erro! Marcador não definido.**

1.4 Metodologia de Investigação ____ 6

1.5 Organização do Documento ____ 7

2 Estado da Arte ____ 8

2.1 Caracterização das Tecnologias de Informação e Comunicação na Administração Pública 8

2.1.1 Custos 8

2.1.2 Maturidade 10

2.1.3 Recursos Humanos 11

2.2 Organização da Função Informática ____ 13

2.3 Centralização ____ 15

2.3.1 Caso de estudo no U.S. Department of Veteran Affairs 15

2.3.2 Citicorp 16

2.4 Auditoria ____ 17

2.5 Certificação ____ 20

2.6 Modelos de Maturidade na Gestão de Sistemas de Informação ____ 21

2.7 Gestão de Serviços Informáticos ____ 23

2.7.1 ITIL V3 24

2.7.2 Limitações do ITIL V3 25

2.7.3 CobiT 4.1 26

2.7.4 Limitações do CobiT 4.1 29

2.7.5 CMMI for Services 29
2.7.6 Limitações do CMMI-SVC 32
2.7.7 Análise Comparativa 32
3 Metodologia Proposta 36
4 Metodologia de Auditoria 39
4.1 Planeamento 39
4.2 Scoping 39
4.3 Execução 41
4.4 Conclusão 42
5 Resultados Obtidos 43
5.1 Auditoria ao DI de Pequena Dimensão 43
5.1.1 Planeamento 43
5.1.2 Scoping 44
5.1.3 Execução 47
5.1.4 Conclusão 49
5.2 Auditoria ao DI de Dimensão Média 50
5.2.1 Planeamento 51
5.2.2 Scoping 51
5.2.3 Execução 52
5.2.4 Conclusão 54
5.3 Auditoria ao DI de Grande Dimensão 54
5.3.1 Execução 55
5.3.2 Conclusão 55
5.4 Análise dos Resultados 56
5.4.1 DI de pequena dimensão 56
5.4.2 DI de dimensão média 58
5.4.3 DI de grande dimensão 58
6 Aprendizagens Adquiridas 60
7 Conclusão 63
7.1 Principais Contribuições 63
7.2 Principais Limitações 64
7.3 Trabalho Futuro 64
8 Referências 66

9 Anexos _____ 70

9.1 Anexo I – Análise de risco alto nível CobiT 4.1 _____ 70

9.2 Anexo II – Análise de maturidade alto nível CobiT 4.1: Exemplo de aplicação ao processo PO1. 72

9.3 Anexo III – Folha de controlo CobiT 4.1: Exemplo para os objectivos de controlo 2 e 3 do processo PO1 . _____ 74

9.4 Anexo IV – Exemplo de evidência para a Actividade de Controlo AI2.CO1.AC1_____ 75

Lista de Figuras

Figura 1 - Quais as principais prioridades dos DI da APP? (Inspecção Geral de Finanças, 2010) 3
Figura 2 - Taxa de crescimento Anual Média 2005 – 2010 (IDC, 2007) 4
Figura 3 - Evolução da despesa em TIC, entre 2005 e 2008 (Inspecção Geral de Finanças, 2010). 9
Figura 4 - Evolução da despesa em TIC por rubrica (Inspecção Geral de Finanças, 2010). 9
Figura 5 - Administração directa e indirecta do Estado – Nível de maturidade em planeamento e organização das TIC, por ministério (Inspecção Geral de Finanças, 2010). 11
Figura 6 – Administração directa e indirecta do Estado – Recursos humanos de TIC, por estrutura habilitacional, 31 de Dezembro de 2005-2007 (Inspecção Geral de Finanças, 2010). 12
Figura 7 – Administração directa e indirecta do Estado – Recursos humanos de TIC, por nível etário (Inspecção Geral de Finanças, 2010). 12
Figura 8 – Administração directa e indirecta do Estado – Recursos humanos de TIC, por recursos humanos de TIC inseridos (e não inseridos) na carreira de informática, 31 de Dezembro de 2005 a 2007 (Inspecção Geral de Finanças, 2010). 13
Figura 9 – Processo de Auditoria (ITGI, 2007). 18
Figura 10 – Processo de certificação ISO/IEC 20000 (Gray, 2007). 20
Figura 11 – Modelo de quatro estádios de Nolan (1973) (Rocha & Vasconcelos, 2004). 22
Figura 12 – Modelo de seis estádios de Nolan (1979) (Rocha & Vasconcelos, 2004). 22
Figura 13 – As três eras de maturidade de Nolan e Mutsaers (1997) (Rocha & Vasconcelos, 2004). 23
Figura 14 – ITIL V3 Core. 24
Figura 15 – Os quatro domínios interligados do CobiT (ITGI, 2007). 27
Figura 16 – Princípio básico da *framework* CobiT 4.1 (ITGI, 2007). 29
Figura 17 – Componentes do modelo CMMI (SEI, 2009) 31
Figura 18 – Domínios de aplicação das diferentes *frameworks.* 33
Figura 19 – Mapeamento entre o ITIL V3 e CobiT 4.1. 34
Figura 20 – Representação genérica da metodologia de solução. 36
Figura 21 – Relação Maturidade Qualidade dos Serviços prestados. 37
Figura 22 – Metodologia de auditoria. 39
Figura 23 – Exemplo de *output* da fase scoping. 41
Figura 24 – Estrutura da *framework* CobiT 4.1. 42
Figura 25 – Relação Performance/Importância do DI de pequena dimensão. 44
Figura 26 – *Scoping* ao nível dos processos. 44
Figura 27 – Responsabilidade e Formalidade dos Processos. 45
Figura 28 - Resultado da avaliação de maturidade de alto nível. 46
Figura 29 – Maturidade por processo após avaliação de alto nível. 46
Figura 30 – Maturidade por domínio após avaliação de alto nível. 47

Figura 31 – Maturidade real por domínio. 48
Figura 32 – Maturidade real por processo. 48
Figura 33 – Classificação segundos os seis vectores de maturidade. 49
Figura 34 – Principais resultados da auditoria ao DI de pequena dimensão. 50
Figura 35 – Relação Performance/Importância do DI de pequena dimensão. 51
Figura 36 – *Scoping* ao nível dos processos. 51
Figura 37 – Resultado da avaliação de maturidade alto nível para o processo ES08. 52
Figura 38 – Maturidade por domínio. 53
Figura 39 – Maturidade por processo. 53
Figura 40 – Classificação segundos os seis vectores de maturidade. 54
Figura 41 – Maturidade por domínio. 55
Figura 42 – Relação custos e nº de DI de pequena dimensão. 61
Figura 43 – Relação Maturidade Qualidade dos Serviços prestados 61

Lista de Tabelas

Tabela 1 - Gastos médios em TIC por funcionário e por rubrica económica (Inspecção Geral de Finanças, 2010). 10
Tabela 2 - Informações do DI de pequena dimensão. 43
Tabela 3 – Informações do DI de dimensão média 50
Tabela 4 – Informações do DI de dimensão grande 55

Lista de Acrónimos

APP	Administração Pública Portuguesa
AMA	Agência para a Modernização Administrativa
CIO	Chief Information Officer
CMMI-SVC	Capability Maturity Model Integration for Services
COBIT	Control Objectives for information and related Technology
DI	Departamento Informático
OP	Organismo Público
GFI	Gestão da Função Informática
GSI	Gestão de Serviços Informáticos
SI	Sistemas de Informação
ITIL	IT Infrastructure Library
IGF	Inspecção Geral de Finanças
ISACA	Information Systems Audit and Control Association
TI	Tecnologias de Informação
TIC	Tecnologias de Informação e Comunicação

1 Introdução

1.1 Enquadramento

A modernização administrativa em Portugal surge, na presente década, como um requisito imposto por drivers externos resultantes de um consenso gerado a nível da União Europeia. Perante a crise financeira actual tornou-se imperativo, para Portugal, a tomada urgente de medidas eficazes para cumprir os objectivos impostos e continuar na sua luta por um país modernizado. A redução de colaboradores da função administrativa, a simplificação dos processos administrativos tendo como foco principal as necessidades do cidadão e a redução de custos com o uso das TI na Administração Pública Portuguesa (APP) são algumas das metas que Portugal se propõe a cumprir (Estrutura Matricial - AMA, 2010).

No seguimento dos objectivos mencionados anteriormente, foi criada uma entidade para, em conjunto com vários organismos públicos (OP), dar suporte a um processo de modernização que se prevê longo e dispendioso. A referida entidade denomina-se AMA - Agência para a Modernização Administrativa, I.P. (AMA, 2009).

Apesar de já serem visíveis alguns dos resultados desta modernização, e.g., cartão do cidadão e portal do cidadão, são muitos os domínios que carecem de uma intervenção rápida e eficaz, do qual, a gestão da função informática (GFI) na APP é exemplo. Este é um dos domínios a necessitar de intervenções urgentes e é o foco de investigação da presente Tese.

O actual estado da GFI na APP é o resultado da necessidade urgente e não controlada de modernização administrativa que ocorreu ao longo de vários anos e que desencadeou a sua descentralização caótica (Tavares, 2004). Assim, diferentes OP, com objectivos semelhantes, detiveram a liberdade necessária para optar pelos seus próprios DI, SI, pelas suas *frameworks* de gestão de serviços informáticos (GSI), ou ausências das mesmas, entre outros (Inspecção Geral de Finanças, 2010). Recorrendo a um estudo intensivo levado a cabo pela IGF no âmbito da caracterização da despesa em TIC na APP (Inspecção Geral de Finanças, 2010), com resultados relativos a Julho de 2010, recaindo sobre 44 entidades num total de 15 ministérios públicos, pode-se afirmar que:

- A despesa em consultoria é hoje a rubrica mais elevada, e regista um crescimento exponencial;
- O aumento da despesa em consultoria está muito associado ao desenvolvimento de software à medida, pelo que também houve um crescimento exponencial desta prática;
- O facto de os gastos de hardware na APP estarem próximos dos gastos em software, mostra que, em muitas entidades, ainda ocorre a fase de equipamento de serviços com grandes preocupações de infra-estrutura.

Este crescimento emergente e não controlado das TI na APP além de constituir um encargo económico anual estimado, actualmente, em 839 milhões de euros (IDC, 2010), originou a criação de

múltiplos sistemas isolados e departamentos informáticos (DI) de dimensão pequena e média. Estes DI trazem várias desvantagens:

- Aumentam os custos associados às TI pois têm dificuldades em implementar economias de escala (Silva & Martins, 2008);
- Provocam agravamento de custos devido à grande dispersão de servidores por todos os organismos onde residem dados necessários ao funcionamento integrado. Assim, o esforço de reconciliação (interfaces) entre diferentes sistemas para responder a necessidades específicas e singulares do negócio de cada entidade aumenta os custos (Inspecção Geral de Finanças, 2010);
- Reduzem a qualidade dos serviços prestados pois não implementam as melhores práticas internacionais (Inspecção Geral de Finanças, 2010);
- Não implementam *frameworks* de GSI (Inspecção Geral de Finanças, 2010);
- Ignoram e não mitigam os riscos, por vezes elevados, associados ao contexto operacional do DI (Inspecção Geral de Finanças, 2010).

A imensa dificuldade em perceber que o valor de negócio das TI está muito para além do *hardware* e *software* (Brynjolfsson & Hitt, 2000), juntamente com a descentralização caótica vivida, constituem factores limitativos da modernização administrativa.

1.2 Definição do Problema

O problema abordado no presente documento incide na organização e gestão da função informática praticada nas organizações que possuem múltiplas unidades de negócio. O âmbito desta investigação está, no entanto, direccionado à APP e incide maioritariamente nos DI de pequena dimensão. A dimensão de um DI é definida tendo em conta os seguintes indicadores – Nº colaboradores, orçamento e quantidade de serviços prestados.

A APP, como organização complexa que é, depara-se com problemas na gestão da função informática (GFI) (Tavares, 2004). Decorrendo de iniciativas individuais e sem coordenação, os sistemas de informação foram surgindo de modo isolado, como se a APP não fosse uma realidade única mas sim um conjunto de organismos independentes e sem relação entre si (Inspecção Geral de Finanças, 2010) (Tavares, 2004). A descentralização caótica da função informática na APP e consequente isolamento local são fenómenos que surgem interligados à necessidade urgente e não planeada da modernização administrativa vivida nos últimos anos.

Este crescimento emergente, isolado e não controlado das TI na APP tem consequências, nomeadamente:

- Por serem OP e não actuarem no mercado, não competem com nenhum outro DI, eliminando, à partida, qualquer vantagem que daí pudesse advir (Silva & Martins, 2008);
- Interoperabilidade de difícil concretização entre os diferentes OP (Inspecção Geral de Finanças, 2010) (Tavares, 2004);

- Replicação desnecessária de informação pelos diferentes SI (Inspecção Geral de Finanças, 2010) (Tavares, 2004);
- Inexistências de economias de escala e conhecimento, levando a:
    - Custos acrescidos (Tavares, 2004) (Romero, 2000) (Silva & Martins, 2008);
    - Gestão imatura da função informática nos DI (Silva & Martins, 2008);
    - Má qualidade nos serviços prestados pelos DI (Silva & Martins, 2008);
- Fraca preocupação com os riscos existentes no contexto operacional do DI, e.g., a nível de segurança (Inspecção Geral de Finanças, 2010).

Todo este processo de informatização independente e local de cada organismo público levou à necessidade de implementação de mecanismos capazes de gerir e manter as TI/SI emergentes. Devido à complexidade dos SI implementados em vários OP, estes sentiram-se na legitimidade de requisitar verbas extra para aquisição de recursos na área de TI/SI ou até mesmo para a criação de DI internos ao organismo (Romero, 2000). Devido à dispersão informática e elevado número de DI existe uma fraca qualidade da função informática na APP. É interessante observar que a integração de sistemas continua a ser das principais preocupações para os DI (Inspecção Geral de Finanças, 2010). Ver figura 1. Este facto é consequência directa da dispersão existente nas TIC.

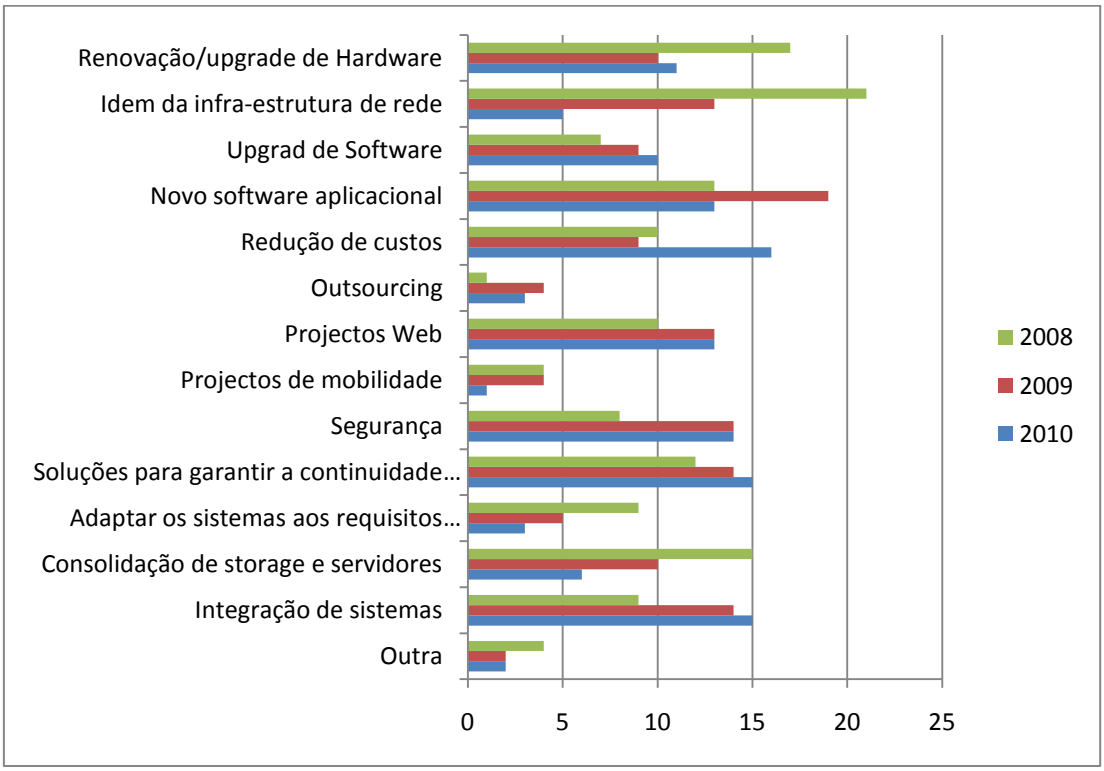


Figura 1 - Quais as principais prioridades dos DI da APP? (Inspecção Geral de Finanças, 2010)

Recorrendo ao mesmo estudo realizado pela IGF (Inspecção Geral de Finanças, 2010) já mencionado na secção anterior, pretende-se comprovar o panorama descrito anteriormente:

- A auditoria às 44 entidades distribuídas pelos 15 ministérios revelou que a média do nível de maturidade situa-se nos 1.6 valores. Valor abaixo do benchmark internacional da ISACA (nível 2 – Repetitivo mas intuitivo);
- 80,5 % dos DI não dispunham de plano estratégico de SI/TI formalizado – apesar de ser um artefacto necessário para gerir e dirigir todos os recursos de TI, de acordo com a estratégia do negócio e as suas prioridades;
- 82,9% dos DI não definiram formalmente uma *framework* de gestão financeira para os investimentos e custos de bens e serviços de TI, com base no portfolio de investimento de TI, negócios e orçamentos de TI;
- 95,1% dos DI não definiram processos para acompanhar os benefícios de TI;
- 82,9% dos DI não adoptam metodologias de gestão de projectos relativos a sistemas e tecnologias de informação;
- Apenas 9,8% dos DI têm sistema de gestão de qualidade;
- A percentagem média de colaboradores ligados às TIC com formação de ensino superior é de apenas 40%, o que leva a um aumento da procura de serviços externos de consultoria.

Os investimentos em TI na APP encontram-se em crescimento (Fig.2) e incidem maioritariamente na compra de serviços externos de consultoria, tendo este tipo de despesa um crescimento exponencial. Este crescimento está directamente relacionado com a necessidade de integração de sistemas e dados entre os diferentes SI e OP que, pela falta de qualificações do colaboradores TIC na APP, fica a cargo de empresas de consultoria. Apenas 40% dos colaboradores de TI possuem habilitações de nível superior.

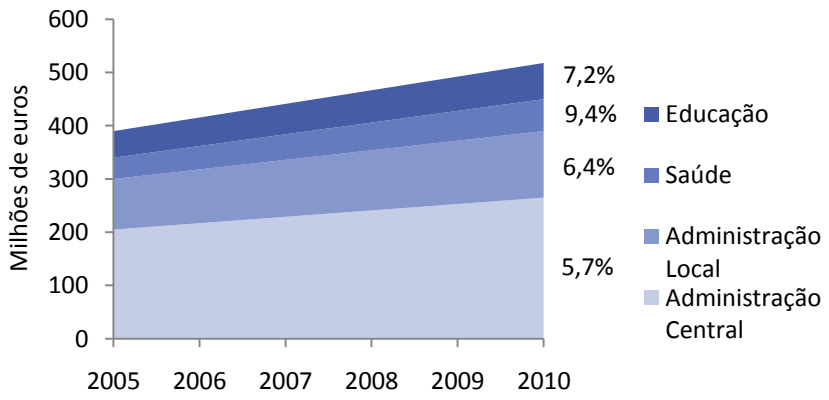


Figura 2 - Taxa de crescimento Anual Média 2005 – 2010 (IDC, 2007)

As TI encontram-se com mais poder de processamento e a um custo cada vez mais reduzido, o que faz com que o seu valor de negócio esteja cada vez menos limitado pela sua capacidade de processamento ou dificuldade de aquisição mas sim, directamente associado à capacidade que os gestores possuem de inventar novos processos, procedimentos e estruturas organizacionais que usufruam verdadeiramente das TI (Brynjolfsson & Hitt, 2000). Torna-se imperativo incutir práticas eficazes de gestão que retirem o verdadeiro valor de negócio que as TI têm para oferecer.

O conceito da descentralização informática como subtema da organização e gestão da função informática está actualmente pouco aprofundado (Gallagher & Worrel, 2008). Apesar de existirem linhas orientadoras bem definidas na área de GSI e várias práticas relacionadas com o Governance de um DI, pode afirmar-se que a organização da função informática é uma área sobre a qual existe pouca investigação (Gallagher & Worrel, 2008). Para as organizações que possuem mais que uma unidade de negócio e que procuram estratégias de TI que melhor suportem a organização como um todo e cada unidade de negócio individualmente, ainda não existem soluções *standard* (Gallagher & Worrel, 2008). Este é de facto o estado da função informática da APP, uma grande organização com múltiplas unidades de negócio onde cada uma possui, por norma, um ou mais DI desenhados para funcionar de modo isolado. Para além de funcionarem como entidades isoladas, cerca de 80% destes DI não possuem um planeamento estratégico definido, capaz de direccionar a sua evolução.

É neste contexto que surge a necessidade de avaliar qual a qualidade e valor acrescido ao negócio que estes DI possuem e trazem, e se estas variáveis estão relacionada com a dimensão dos DI. É necessário perceber qual o verdadeiro impacto da descentralização nas TI e consequente aumento de DI de pequena dimensão em Portugal, medindo para isso a maturidade e qualidade dos serviços prestados pelos DI de dimensões pequena, média e grande.

O problema da presente Tese consiste, assim, na seguinte pergunta: Qual a correlação existente entre as variáveis nível de maturidade, dimensão e qualidade dos serviços dos DI?

Os autores, com esta investigação, pretendem aferir se existem DI que não justificam a sua existência.

Ainda na problemática exposta anteriormente, pode-se afirmar que os problemas causados pela descentralização não são exclusivos a Portugal, tendo ocorrido no sector da saúde, na Finlândia, com o uso do Registo Electrónico do Paciente (REP) (Harno, Ruotsalainen, Nykänen, & Kopra, 2008). Com a maioria dos centros médicos a utilizarem sistemas baseados no REP mas sem qualquer tipo de standard tecnológico, a interoperabilidade tornou-se difícil de concretizar, o *governance* demasiado descentralizado e os custos elevados. Este problema surgiu por falta de planeamento nas TI e originou um projecto de centralização com o objectivo de aumentar a interoperabilidade entre sistemas e consequente diminuição de custos (Harno, Ruotsalainen, Nykänen, & Kopra, 2008).

Pode-se referir, ainda, que já em 1996 se demonstrava alguma preocupação com a temática dos níveis de maturidade da GFI na APP, tendo sido conduzido um estudo no âmbito de uma Tese de

Mestrado com o objectivo de verificar a evolução da função SI nos Serviços de informática de grande dimensão da APP (Santos, 1996). O âmbito da referida tese foi, no entanto, verificar qual a evolução que cada organismo de grande dimensão obteve em separado, e não, analisar a GFI da APP como um todo.

1.3 Objectivos

Pelos problemas enunciados na secção anterior, surge a necessidade de evidenciar e quantificar a GFI de baixa qualidade praticada na APP, através do uso de modelos de maturidade. Durante esta investigação, serão auditados 3 DI da APP de dimensões pequena, média e grande com o objectivo de avaliar o seu nível de maturidade relativamente às TI. Através dos dados obtidos pretende-se explorar o estado da GFI na APP e, assim, concretizar as actividades enumeradas de seguida:

- Auditar e classificar 3 DI da APP segundo a *framework* CobiT 4.1. e efectuar um conjunto de sugestões de melhoria com o objectivo de evoluir a sua maturidade;
- Verificar se os DI de dimensão pequena estão atrás do eixo 1, definido na secção 3;
- Analisar e clarificar a qualidade da GFI da APP através do uso de modelos de maturidade;
- Analisar a correlação existente entre as variáveis nível de maturidade, dimensão e qualidade dos serviços nos DI.

1.4 Metodologia de Investigação

Como metodologia de investigação foi escolhida a *Case Study Research*. Este método de investigação define-se como sendo uma pesquisa empírica que investiga um fenómeno contemporâneo dentro de seu contexto aplicacional usando várias fontes de informação (Baxter & Jack, 2008).

Em geral, os elementos criados a partir deste tipo de estudo são considerados muito seguros e fiáveis, no entanto, este método pode requerer muito tempo de investigação e custos adicionais (Baxter & Jack, 2008).

Esta metodologia de investigação pressupõe a realização dos seguintes passos (Baxter & Jack, 2008):

- **Definição da pergunta a responder** – Qual o nível de maturidade que os departamentos informáticos (DI) analisados possuem segundo a *framework* CobiT 4.1. Qual a correlação existente entre as variáveis nível de maturidade, dimensão e qualidade dos serviços nos DI?
- **Definir qual o tipo de caso de estudo a realizar** – O objectivo deste caso de estudo reside em efectuar comparações entre diversos casos de estudos individuais através do método *Multiple-case studies*. Este método permite analisar informação relativamente a casos de estudo individuais, e cruzar a informação resultante de todos os casos, para evidenciar semelhanças ou diferenças.

- **Definição das fontes de dados** – As fontes de dados a utilizar serão todas as que um processo de auditoria pressupõe, e.g., entrevistas, inquéritos, documentos, observações directas, etc. Como fonte de dados auxiliar, irá utilizar-se informação relativa a estatísticas nacionais, e.g., número e dimensão de DI, número de colaboradores por DI, custos associados, etc.
- **Definição do método de análise** – Será analisada a oscilação de algumas variáveis, definidas e clarificadas na secção 3, segundo a evolução dos níveis de maturidade CobiT. O método de análise a utilizar deverá permitir encontrar padrões de oscilação entre as demais variáveis e dados estatísticos. Assim, será escolhido o método de análise *pattern matching*.

1.5 Organização do Documento

Descreve-se agora a estrutura do presente documento. Na secção 2, é efectuada uma análise crítica e comparativa relativamente às melhores práticas no domínio da GSI assim como a descrição de alguns conceitos relacionados. Na secção 3 é descrita a metodologia proposta. A secção 4 descreve a metodologia de auditoria utilizada durante a investigação. Os resultados obtidos estão descritos e criticados na secção 5 e na secção 6 descrevem-se as aprendizagens adquiridas.

2 Estado da Arte

Nesta secção pretende-se rever o estado da arte no domínio da GSI, assim como abordar conceitos subjacentes ao tema, obtendo-se desta forma uma percepção mais alargada das *frameworks* que vigoram actualmente na indústria nacional e internacional.

Nas secções 2.1 a 2.6 abordam-se seis conceitos importantes e directamente ligados às *frameworks* de GSI, e.g.: Caracterização das TIC na APP, Organização da Função Informática, Centralização, Auditoria, Certificação e Modelos de Maturidade na Gestão de Sistemas de Informação. Na secção 2.7 refere-se de forma descritiva e crítica três *frameworks* na área: ITIL V3, CobiT 4.1 e CMMI-SVC V1.2 com o objectivo de perceber qual a mais adequada ao suporte da metodologia referida na secção 3. Por último é efectuada uma comparação entre as três *frameworks* com especial enfoque no CobiT 4.1 e ITIL V3, dada a sua complementaridade.

2.1 Caracterização das Tecnologias de Informação e Comunicação na Administração Pública

Nesta secção serão descritos alguns dos indicadores mais importantes sobre o uso e evolução das TIC, produzidos pela IGF no âmbito de um estudo realizado à APP com uma representatividade da amostra seleccionada de 54,08% (a nível de orçamento). Este estudo recaiu sobre 44 entidades, num total de 15 Ministérios Públicos (Inspecção Geral de Finanças, 2010). Nesta secção pretende-se situar e informar o leitor do real estado da função informática na APP. As informações que se seguem baseiam-se integralmente no referido estudo efectuado pela IGF.

2.1.1 Custos

Os cálculos globais da despesa em TIC e da despesa total, desde 2005 a 2008, na APP conduziram ao rácio de 3,6% (despesa TIC / despesa total).

Na amostra analisada, entre 2005 e 2008, a despesa em TIC apresenta um crescimento positivo de 25,8% (Fig. 3 – unidade: milhares de euros):

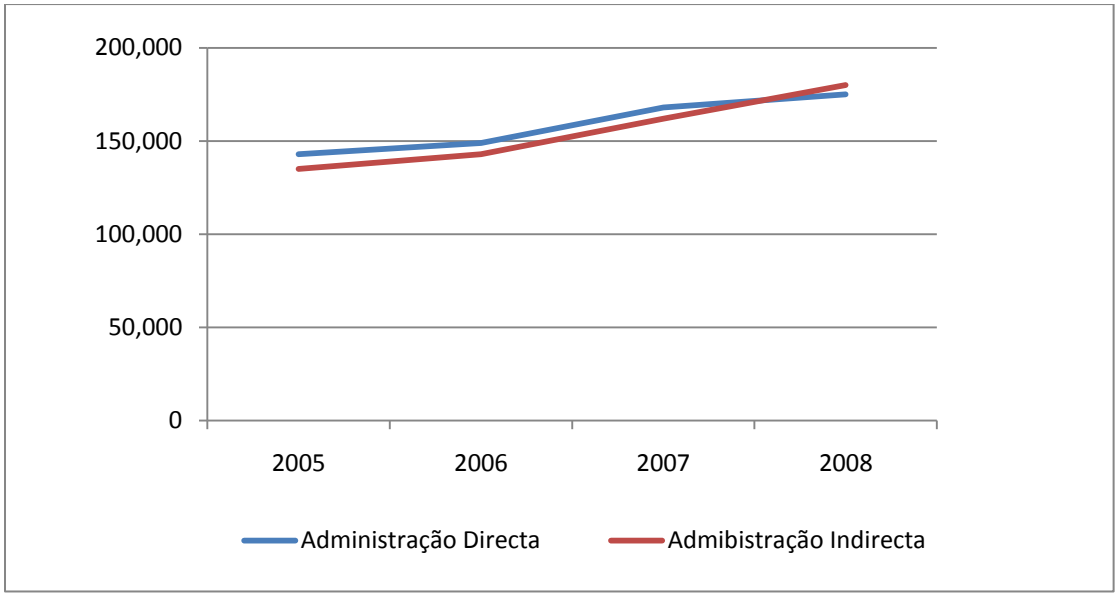


Figura 3 - Evolução da despesa em TIC, entre 2005 e 2008 (Inspecção Geral de Finanças, 2010).

O gráfico (fig. 4 – unidade: milhares de euros) que se segue apresenta a evolução da distribuição da despesa em TIC por rubrica económica no período 2005-2008:

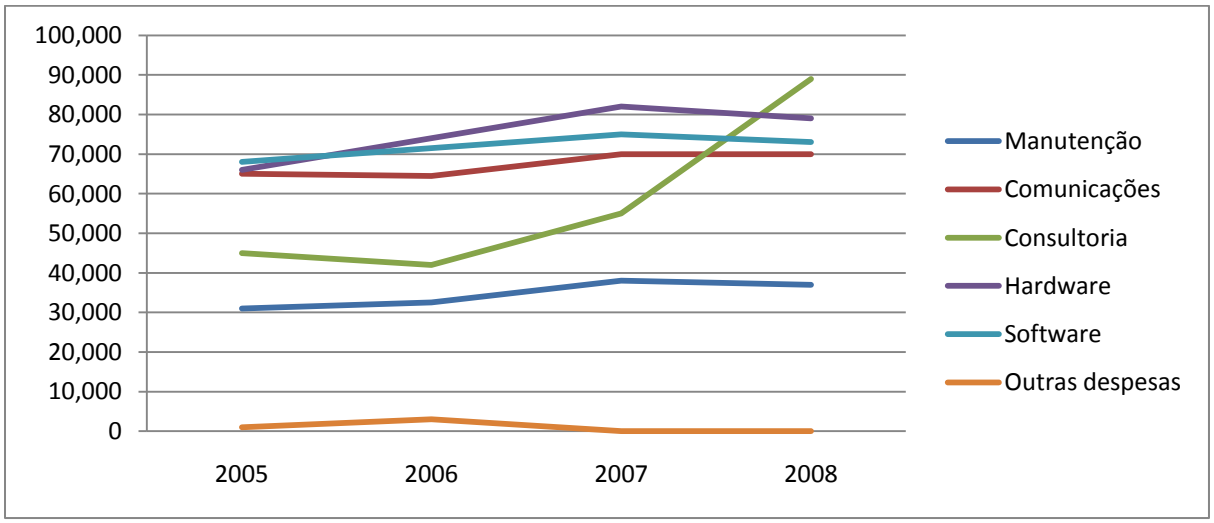


Figura 4 - Evolução da despesa em TIC por rubrica (Inspecção Geral de Finanças, 2010).

Sobre este gráfico interessa realçar os seguintes aspectos:

- É notório um crescimento exponencial na despesa em consultoria. Este crescimento pode indicar uma dependência superior relativamente aos grandes fornecedores;
- As despesas com comunicações são relativamente elevadas devido aos custos dos circuitos de comunicações. Foram também identificados casos onde os custos de comunicação em papel são relativamente elevados;
- As despesas em hardware estão estabilizadas e serão ultrapassadas pelas de software quando os serviços ficarem equipados.

No estudo realizado pela IGF (Inspecção Geral de Finanças, 2010) é indicado que o gasto médio em TIC por funcionário permite perspectivar qual o orçamento adequado a um DI através do seu nº de colaboradores. Ou seja, é referido que se um DI informático possuir x colaboradores então o seu orçamento de TIC deverá ser de 561 * x. Esta ideia parece fracamente sustentada uma vez que são desvalorizados os DI que, apesar de possuírem orçamentos desproporcionais ao seu nº de colaboradores, conseguem fornecer serviços em grande quantidade e qualidade a um número elevado de cidadãos.

A tabela seguinte ilustra os gastos médios por funcionários (em €) e por rubrica económica (em milhares de €), relativos ao universo observado:

Rubrica	Média Anual (2005-2008)	Despesa TIC por Funcionário (Em €)
Comunicações	66.972	122
Hardware	75.185	137
Software	72.180	132
Consultoria	57.500	105
Manutenção	34.413	63
Outras despesas	1.135	2
Total	**307.386**	**561**

Tabela 1 - Gastos médios em TIC por funcionário e por rubrica económica (Inspecção Geral de Finanças, 2010).

2.1.2 Maturidade

No âmbito do estudo realizado pela IGF foram também auditadas todas as 44 entidades através da *framework* CobiT 4.1. As auditorias incidiram apenas no primeiro domínio da *framework* – Planeamento e Organização e o resultado médio obtido foi de 1.6 valores numa escala de 0 a 5. Apesar de existirem alguns ministérios com classificação superior ao benchmark internacional da ISACA (2 valores), estes são apenas uma excepção à fraca qualidade da função informática na APP. O gráfico seguinte resume as classificações obtidas pelos 15 Ministérios Públicos:

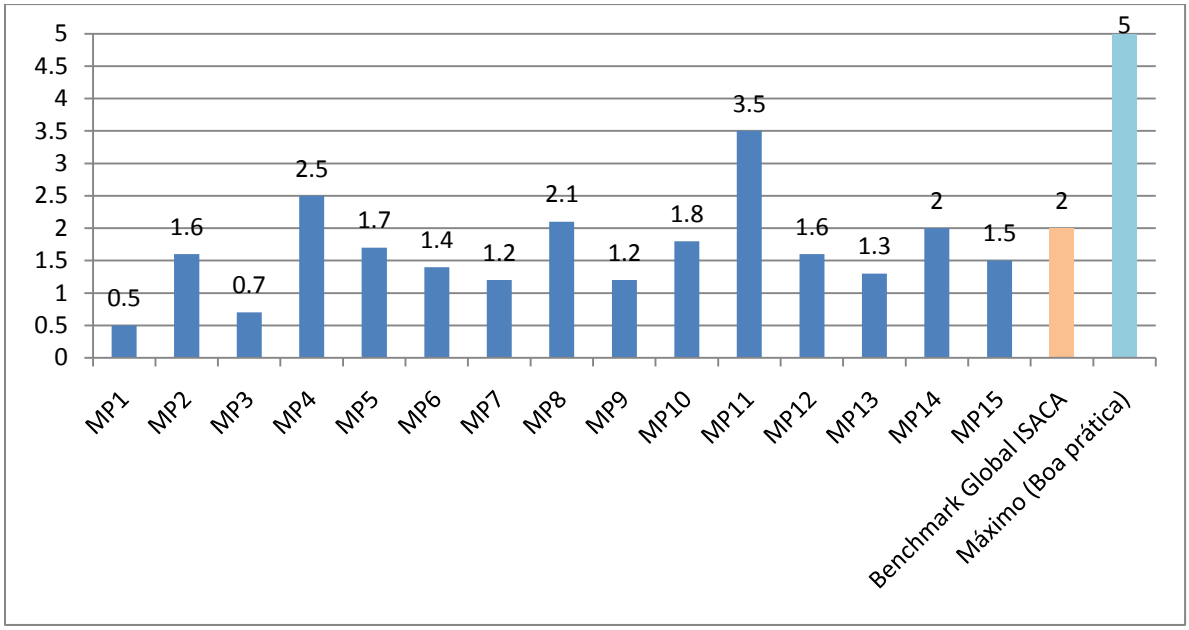


Figura 5 - Administração directa e indirecta do Estado – Nível de maturidade em planeamento e organização das TIC, por ministério (Inspecção Geral de Finanças, 2010).

2.1.3 Recursos Humanos

A percentagem de trabalhadores destacados para as áreas de TIC na APP é de 1,99%. Constata-se, assim, que a percentagem de recursos humanos é pouco significativa, em especial nos organismos pertencentes à Administração directa do Estado. Provavelmente, esta percentagem reduzida não se deve à falta de colaboradores TIC mas sim ao excesso de colaboradores fora do contexto TIC na APP.

A qualificação dos colaboradores TIC é um factor importante na medida em que está directamente relacionada com a qualidade dos serviços prestados. Encontram-se ilustradas no gráfico seguinte as habilitações dos recursos humanos TIC:

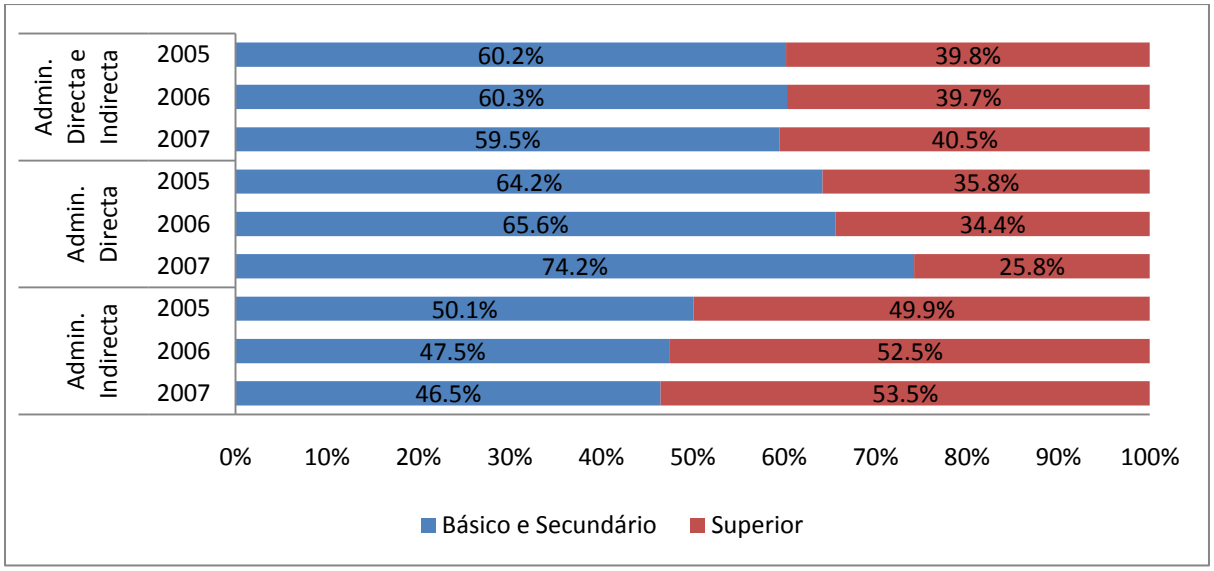


Figura 6 – Administração directa e indirecta do Estado – Recursos humanos de TIC, por estrutura habilitacional, 31 de Dezembro de 2005-2007 (Inspecção Geral de Finanças, 2010).

Na Administração directa do Estado conclui-se que com o decorrer dos anos tem vindo a baixar o nível de escolaridade dos trabalhadores, reduzindo ligeiramente a taxa de recursos humanos com cursos superiores. A falta de competências de TIC adequadas e insuficiência de conhecimentos, leva à degradação dos serviços e aumento de erros e incidentes. Convém ainda frisar que a falta de recursos humanos qualificados em TIC nas entidades pode condicionar e transferir o poder de decisão da APP para os fornecedores.

A figura seguinte apresenta a evolução e distribuição média dos recursos humanos TIC, por nível etário, na Administração directa e indirecta do Estado:

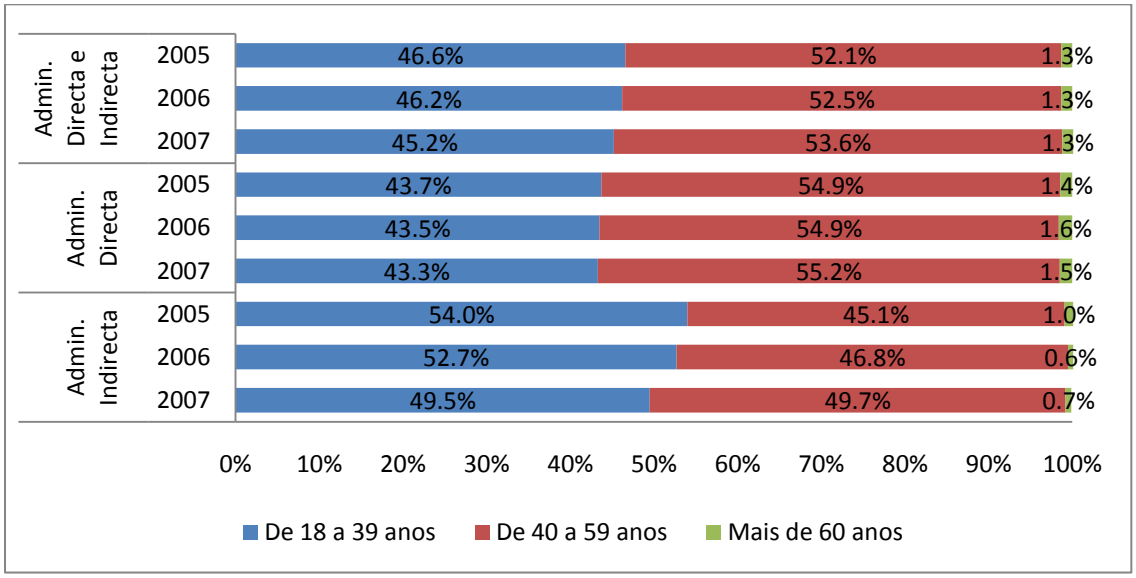


Figura 7 – Administração directa e indirecta do Estado – Recursos humanos de TIC, por nível etário (Inspecção Geral de Finanças, 2010).

A Administração directa e indirecta do Estado é caracterizada, globalmente, pela existência de uma população de pessoas de TIC relativamente menos jovem, representando os escalões etários entre os 40 e 59 e com mais de 60 anos, mais de 54% dos recursos humanos de TIC. Existe, portanto, um envelhecimento dos colaboradores de TIC activos.

A figura apresentada de seguida representa a evolução e distribuição média dos recursos humanos TIC, por recursos humanos de TIC inseridos e não inseridos na carreira de informática, na Administração directa e indirecta do Estado:

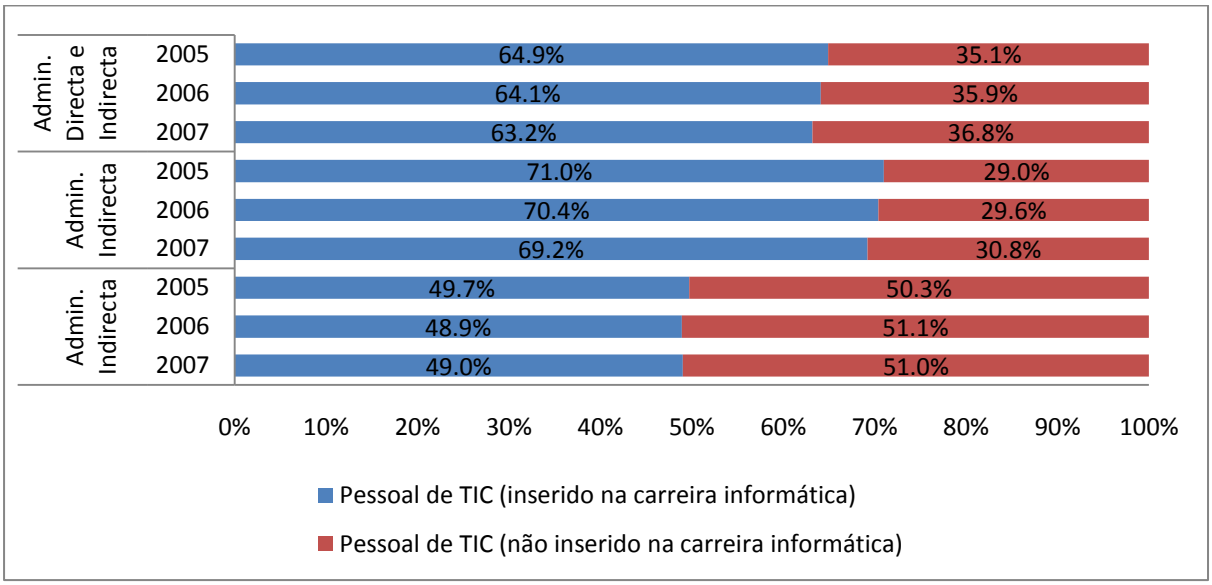


Figura 8 – Administração directa e indirecta do Estado – Recursos humanos de TIC, por recursos humanos de TIC inseridos (e não inseridos) na carreira de informática, 31 de Dezembro de 2005 a 2007 (Inspecção Geral de Finanças, 2010).

Através da figura 8 é perceptível um aumento progressivo da percentagem de recursos humanos de TIC não inseridos na carreira de informática, constatando-se que, entre 2005 e 2007, em média, cerca 35,9% dos recursos humanos de TIC não se encontram inseridos na carreira de informática.

Ainda relativamente ao estudo efectuado pela IGF, o rácio de recursos humanos TIC sobre os recursos humanos globais é de 12,5%.

2.2 Organização da Função Informática

Com a expansão e internacionalização de todos os mercados, as empresas desenvolveram estratégias e mecanismos para se adaptarem a uma nova realidade. A segmentação de empresas em várias unidades de negócio com o objectivo de se tornarem mais ágeis nos ambientes competitivos locais, tornou-se uma prática corrente (Sambamurthy & Zmud, 1999). No suporte a todo esse crescimento a nível de negócio e para satisfação da dinâmica organizacional requerida, as TI desempenham, de facto, um papel importante (Gallagher & Worrel, 2008).

Apesar de existirem linhas orientadoras bem definidas na área de GSI e várias práticas relacionadas com o *Governance* de um DI, pode-se afirmar que a organização da função informática

é uma área sobre a qual existe pouca investigação (Gallagher & Worrel, 2008). Para as organizações que possuem mais que uma unidade de negócio e que procuram estratégias de TI que melhor suportem a organização como um todo e cada unidade de negócio individualmente, ainda não existem soluções *standard* (Gallagher & Worrel, 2008).

O modo como é praticado IT governance tem evoluído segundo um padrão e surge directamente ligado às tecnologias disponíveis na época (Peterson, O'Callahan, & Ribers, 2000). Na década de 1970 verificou-se uma tendência de centralização, em 1980 o IT governance progrediu para a descentralização e, em 1990, existiu uma recentralização.

O *governance* da função TI determina onde reside o poder de decisão na organização (Sambamurthy & Zmud, 1999), podendo este assumir uma das seguintes estruturas: centralizado, descentralizado ou organizado em estruturas federais (híbrido) (Brown & Magill, 1994). Cada uma das tipologias acarreta uma série de vantagens e desvantagens, assim como implica diferentes papéis e responsabilidades no processo de decisão relacionado com as TI. Uma estrutura centralizada promove o desenvolvimento de processos bastante eficientes na gestão das TI enquanto o uso de uma estrutura descentralizada permite, com maior facilidade, aumentar a eficácia das unidades de negócio locais. As estruturas centralizadas permitem obter economias de escala e conhecimento com mais facilidade. As estruturas federais ou híbridas são uma espécie de meio-termo e permitem que as organizações possuam apenas algumas funções partilhadas e outras centralizadas, e.g., infra-estruturas.

A investigação referenciada por (Peterson, O'Callahan, & Ribers, 2000), focada nas estruturas híbridas e mecanismos de integração retirou as seguintes conclusões:

- A adopção de estruturas híbridas para o IT governance depende da orientação estratégica do negócio e das TI:
    - A orientação estratégica focada na inovação está associada a uma configuração híbrida onde a administração/gestão do negócio desempenha um papel fundamental.
- A excelência operacional e a inovação a que as organizações se comprometem aumentam a descentralização do poder de decisão.
- Em ambientes competitivos, o IT governance efectivo preocupa-se com o estabelecimento de uma rede de ligações organizacionais ao invés de uma estrutura hierárquica clássica.
- O desafio para a gestão é aprender como gerir a descentralização e centralização, no entanto, a centralização é o processo que mais dificuldades apresenta.

Se encararmos a APP como uma organização de tamanho considerável que possui várias unidades de negócio espalhadas pelo país, com necessidades e objectivos diferentes, então facilmente se percebe que a problemática da organização e gestão da função informática se estende à APP.

2.3 Centralização

A centralização no domínio das TI, como referido na secção anterior, apesar de ser um processo bastante complexo, possibilita reduzir custos de um modo bastante eficiente. Para corroborar esta ideia serão descritos dois casos de estudo com o objectivo de demonstrar as vantagens da centralização das TI. O primeiro caso de estudo é na função pública dos Estados Unidos da América, e o segundo na empresa CitiCorp.

2.3.1 Caso de estudo no U.S. Department of Veteran Affairs

A centralização das TI numa organização já ocorreu nos E.U.A. numa organização pública, mais concretamente no *U.S. Department of Veteran Affairs (VA)* (Walters, 2009). Para compreender a complexidade e dificuldades presentes neste projecto é necessário perceber a dimensão que a organização VA possui. A VA é actualmente constituída por três unidades principais:

- **Veterans Health Administration (VHA)** – Responsável pelo sistema de saúde.
- **Veterans Benefit Administration (VBA)** – Responsável por assegurar as pensões e outros benefícios dos veteranos.
- **National Cemetery Administration (NCA)** – Responsável por gerir funerais e cemitérios.

A unidade maior e que foi o principal foco deste projecto é a VHA, com um orçamento de 35 mil milhões de dólares e que é constituída, entre outros, por 155 centros médicos, 872 clínicas ambulatórias e 135 centros de enfermagem. Em 2008 o VHA servia 7.8 milhões de veteranos e possuía uma força de 200.000 profissionais na área da saúde. A informação desempenha um papel crucial nesta organização pois é parte integrante do seu *core business* salvaguardar enormes quantidades de informação resultante de investigações científicas directamente relacionadas com os veteranos, desde problemas cardíacos, traumas psicológicos e físicos, etc. Realçando ainda mais a criticidade desta unidade, é da sua responsabilidade funcionar como sistema de saúde alternativo em caso de desastres nacionais, como aconteceu após o furacão *Katrina.*

Os principais drivers para a realização deste projecto foram:

- Os SI estavam completamente descentralizados.
- Apenas 3% dos DI tinham o seu orçamento acessível e controlado pelo CIO do VA. As decisões orçamentais estavam completamente desalinhadas com a estratégia das TI.
- O CIO tinha controlo apenas sobre 6% dos colaboradores de TI.
- Falhas de segurança que comprometeram informação confidencial de 26 milhões de veteranos.

O objectivo genérico deste projecto era desenvolver capacidades nas TI que garantissem a integração, fiabilidade e eficácia da informação que suporta os serviços de saúde. Para tal pretendia-

se centralizar as TI, os seus colaboradores, a administração, o desenvolvimento de software, etc., criando uma estrutura eficaz de *IT Governance.* Foram adaptadas e usadas as melhores práticas de *framework*s como o CobiT e o ITIL.

Apesar de não terem sido disponibilizados números relativos à redução de custos alcançada com este mega projecto, interessa reter que, mesmo numa organização extremamente complexa e com dimensões superiores a muitas da unidades públicas a funcionarem em Portugal, é possível concretizar com sucesso projectos de centralização e redução de custos nas TI que levam a um posterior aumento da qualidade dos serviços prestados. Os principais resultados alcançados pela VA foram:

- Desenvolveram e disseminaram um plano estratégico de TI que guiou e objectivou as iniciativas nas TI e alinhou os resultados pretendidos com o planeamento estratégico dos DI.
- Foram analisados os custos das TI nas várias unidades e, com base nas informações obtidas, desenvolveu-se uma ferramenta de previsão de orçamentos e de gestão de custos a um nível global da organização.
- Criou-se uma metodologia robusta de monitorização e reporte de performance das equipas e dos projectos em que estavam inseridas.
- Centralizou-se o processo de gestão de qualidade do *software* e estabeleceu-se requisitos de melhores práticas para o seu desenvolvimento.
- Desenvolveu-se e implementou-se uma ferramenta exaustiva de avaliação e gestão de todos os aspectos relacionados com a segurança de informação.
- Criou-se uma *data warehouse* para padronizar a gestão e armazenamento de toda a informação.

2.3.2 Citicorp

Nesta secção refere-se um caso de estudo sobre um processo de centralização de operações que ocorreu no Citibank (Soh & Siong, 1995). Em 1991 a Citicorp registou um prejuízo líquido de $ 457 milhões. Este prejuízo deveu-se em grande parte à percentagem elevada de empréstimos concedidos a países de terceiro mundo pela sua instituição financeira Citibank. Para combater o abrandamento de receitas e o crescimento de créditos com elevado risco, a Citicorp reduziu custos de modo agressivo, aumentando assim a sua margem de operação.

O CEO da Citiporp, John Reed, iniciou nesse mesmo ano um processo de reestruturação organizacional onde articulou três requisitos essenciais para ser um banco de excelência na década de 1990 – Ir ao encontro das necessidades do cliente, ter poder financeiro e conjugar os recursos humanos e tecnológicos de um modo criativo mas contido a nível de custos. A estratégia do Citibank consistia em garantir que o banco estava a um clique, um milha ou a um telefonema de distância em qualquer parte do mundo para com qualquer cliente.

Sendo este um banco internacional e com uma forte presença no continente Asiático procurou, ao longo da sua evolução, explorar o mercado de que dispunha da melhor maneira possível. Assim,

especializou-se nos mercados locais de modo a servir as necessidades de cada cliente e ao mesmo tempo respeitar as normas e restrições que cada país impunha. Este facto levou a que ao fim de anos de descentralização, o *software* e tipo de aplicações existentes em cada unidade de negócio tivessem diferenças significativas.

Embora a descentralização tenha sido uma estratégia válida no contexto evolutivo inicial da organização, veio-se a revelar uma má prática. O facto de dificultar a concretização da interoperabilidade assim como a recolha de informação vital à boa governação da organização como um todo levou a um processo de reestruturação organizacional. A descentralização local não permitia a integração dos seus produtos, serviços e informações de um modo coeso e capaz de servir as características do mercado actual.

A nova estratégia do Citibank procurava alcançar economias de escala através da centralização dos seus produtos bancários e respectivos processamentos, efectuados em diversas regiões da Ásia. Esta estratégia contemplava a reestruturação da camada tecnológica, para se adequar às novas necessidades de negócio. Devido aos custos e prazos incomportáveis associados a um projecto cujo domínio englobasse toda a actividade do Citibank, decidiu-se avançar com um projecto-piloto que afectou as unidades de negócio de Hong-Kong e Singapura. Este consistia em concentrar todas as operações de processamento relacionadas com cartões de crédito, na unidade de Singapura. O tempo de implementação foi de 8 meses e as reduções de custos por cartão de crédito foram de 45% em 1990. Devido ao sucesso do projecto-piloto o seu âmbito foi, numa primeira fase, alargado para o Médio Oriente e Norte Asiático e, em 1999, encontrava-se implementado em 27 países. O custo médio por cartão em apenas 3 anos foi reduzido em mais de 40%.

2.4 Auditoria

O processo de auditoria a SI pode ser definido como o processo de recolha e avaliação de provas para determinar se um SI mantém a integridade dos seus dados, está alinhado com os objectivos organizacionais de negócio e consome os recursos existentes de forma eficiente (ISACA, 2009).

Os SI são, hoje em dia, vitais a qualquer negócio de grande dimensão e, como tal, as organizações sentem a necessidade de recorrer frequentemente a este tipo de avaliações quer para efectuar melhorias internas quer para aumentar a sua credibilidade diante dos seus clientes, através da materialização do valor dos seus serviços e produtos sob a forma de um bom resultado no processo de auditoria. Existem *drivers* externos que também contribuem para o crescimento deste mercado.

Em Portugal, por exemplo, a Inspecção Geral de Finanças (IGF) efectua auditorias regulares com base na *framework* CobiT 4.1. aos OP.

Os problemas abordados por este tipo de auditorias podem ser agrupados nos seguintes pontos principais (ISACA, 2009):

- **Disponibilidade** – Os SI em que o negócio é altamente dependente estão disponíveis sempre que necessário? Os SI estão protegidos contra todos os tipos de perdas e desastres?

- **Confidencialidade** – As informações usadas nos SI são divulgadas segundo políticas de segurança e privacidade?
- **Integridade** – A informação fornecida pelos SI é sempre precisa, confiável e oportuna?
- **Eficácia** – A informação é relevante para o negócio e entregue de maneira consistente, correcta, dentro dos *timings* previstos e de maneira usável?
- **Retorno de Investimento** – O SI retorna o investimento inicial dentro do tempo previsto?

Um relatório técnico sobre como efectuar auditorias a uma organização pode ser consultado na referência (ITGI, 2007). Este, apesar de descrever o processo de auditoria como um método genérico e incluir até uma actividade de escolha de uma qualquer *framework* de controlo, é preferencialmente orientado a auditorias baseadas na *framework* CobiT 4.1.

Pelas razões apresentadas na secção 3, a metodologia de auditoria será baseada na *framework* CobiT. Como tal, esta será descrita de seguida. O *Assurance process*, como é denominado no relatório técnico referenciado em (ITGI, 2007), consiste em três actividades principais representadas na figura 9.

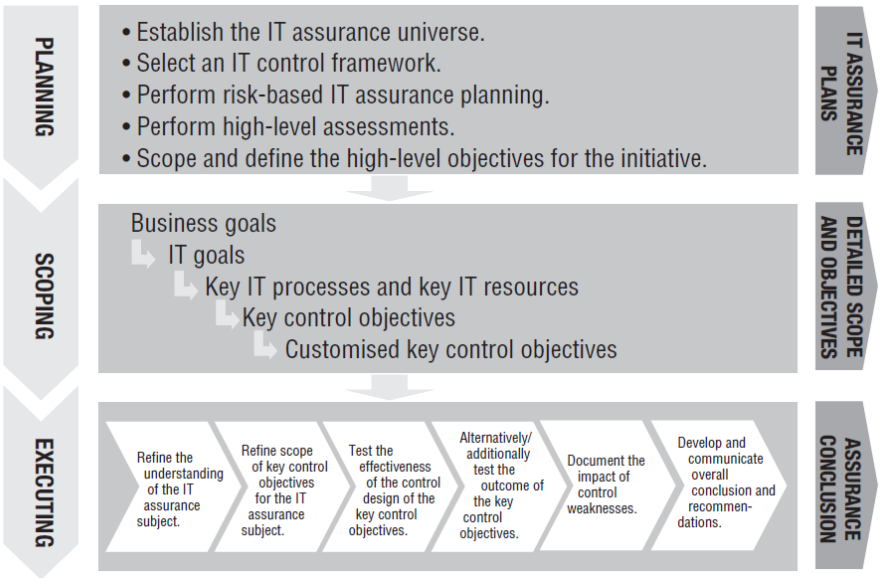


Figura 9 – Processo de Auditoria (ITGI, 2007).

A actividade de *Planning* divide-se nas seguintes sub-actividades:

- ***Establish the IT assurance universe*** – O *IT assurance universe* define qual a área de responsabilidade de actuação do auditor e é composto por unidades, pessoas, processos, procedimentos, sistemas, etc.
- ***Perform risk-based IT assurance planning*** – O auditor deverá usar uma técnica de análise de risco apropriada com o objectivo de identificar as unidades do *assurance universe* com maior necessidade de intervenção.
- ***Perform high level assessments*** – Para um melhor planeamento e estabelecimento de prioridade no processo de auditoria, deverão ser feitas avaliações de alto nível com o

objectivo de perceber quais os pontos críticos de actuação, ou seja, identificar quais os pontos em que a diferença do *as-is* e *to-be* se revela maior.

- ***Scope and define the high-level objectives for the initiative*** – O *scope* e objectivos da iniciativa deverão estar bem definidos. As avaliações de alto-nível ao controlo interno das funções ou actividades que irão ser auditadas também se revelam importantes neste contexto. São fornecidos alguns diagramas úteis em (ITGI, 2007), contudo o relatório técnico referenciado em (ITGI, 2007) é mais adequado a avaliações de alto nível.

A actividade de Scoping contém 8 sub-actividades:

- ***Establish Drivers for the assurance Initiative*** – Delinear qual o objectivo da auditoria, e.g., melhoria de processos, classificação/posicionamento no mercado, etc.
- ***Document Enterprise IT Architecture*** – Documentar, de forma genérica a Arquitectura Empresarial da organização em questão.
- ***Select Control frameworks*** – É escolhida a *framework* de controlo.
- ***Identify IT Processes*** – Escolher os processos a incluir no *scope* da auditoria.
- ***Select IT Components*** – Escolher os recursos, e.g., aplicação, informação, infra-estrutura ou pessoas, a incluir no *scope*.
- ***Refine IT Component Selection*** – Garantir que os recursos incluídos têm uma relação directa com os processos relevantes à auditoria.
- ***Select Control Objectives*** – Seleccionar os objectivos de controlo relevantes no *scope* da auditoria.
- ***Refine Control Objectives Selection*** – Eliminar os objectivos de controlo que, caso não sejam atingidos, não tenham um efeito material.

A actividade de *Executing* é constituída por 6 sub-actividades:

- ***Refine Understanding*** – Aprofundar o conhecimento sobre o contexto em que os testes irão ser executados. Documentar as evidências tendo em conta as perguntas “quem”, “onde” e “quando”, os *inputs* e *outputs* das tarefas subjacentes à evidência, assim como os procedimentos usados para a executar.
- ***Refine Scope*** – A fase de *scoping* anterior poderá necessitar de ser revista para determinar um sub-conjunto final, alvo da iniciativa. Para tal, dever-se-á executar os seguintes passos: *Analyse Business and IT Goals, Select Processes and Controls, Analyse Risks* e *Finalise Scope.*
- ***Test the Control Design*** – São efectuados testes para avaliar o desenho dos controlos, a sua eficácia operacional e verificar a sua aplicação efectiva no local.
- ***Test the Outcome of the Control Objectives*** – O auditor deverá encontrar evidências directas ou indirectas respectivas ao momento actual da auditoria que garantam diversas propriedades dos controlos. Esta actividade, dependendo do auditor, pode ser usada para complementar ou substituir a anterior.

- ***Document the Impact of Control Weaknesses*** – Documentar a análise efectuada aos controlos com o objectivo de explicitar os riscos e fraquezas encontradas nos componentes auditados.
- ***Develop and Report Overall Conclusion and Recommendations*** – Comunicar os resultados da auditoria aos *stakeholders* interessados.

2.5 Certificação

O processo de certificação organizacional consiste em avaliar uma organização e testar a sua conformidade com uma determinada *framework*. Caso o resultado dessa avaliação satisfaça os requisitos mínimos de aprovação, então a organização passa a ser acreditada pela norma em questão. Existem diversas entidades certificadoras que estão habilitadas a certificar organizações segundo várias normas. Uma dessas entidades, com actividade em Portugal, é a itSMF (itSMF, 2009).

O número de certificações concedidas no domínio da GSI, e.g, ITIL, ISO 9001, ISO 20000, CMMI, etc., aumentou exponencialmente nos últimos anos como consequência directa da crescente procura de serviços com fiabilidade e qualidade (IDC, 2010). A itSMF conta, até à data, com mais de 400 empresas certificadas na norma ISO/IEC 20000 em todo o mundo. De seguida ilustra-se o plano de certificação da norma ISO/IEC 20000 na figura 10 juntamente com uma explicação sucinta de todos os passos (Gray, 2007):

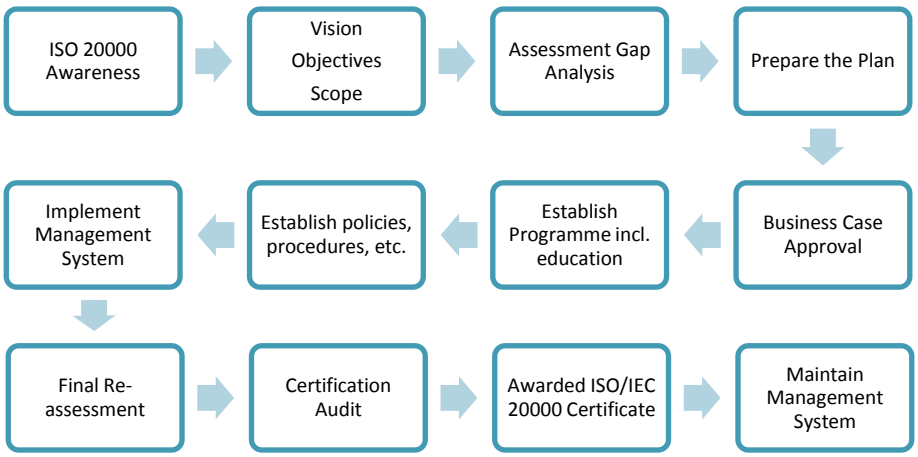


Figura 10 – Processo de certificação ISO/IEC 20000 (Gray, 2007).

- **ISO 20000 Awareness** – Obter o *commitement* por parte dos *stakeholders* chave da organização, e.g., director de TI, equipa de gestão, etc.
- **Vision, Objectives e Scope** – A equipa de gestão deverá definir a visão – "O que estamos a tentar alcançar?" – os objectivos – "Porque estamos a fazer isto?" e o *scope* – "Que recursos é que estão envolvidos?".

- **Assessment Gap Analysis** – Examinar a organização com o objectivo de encontrar todas as não-conformidades.
- **Prepare the Plan** – Deve ser definido o projecto para implementação da ISO/IEC 20000.
- **Bussiness Case Approval** – Conceber um caso de negócio de forma a testar o plano desenvolvido num contexto limitado.
- **Establish Programme incl. education** – Seleccionar o método de gestão do projecto e o respectivo responsável, alocar os recursos e iniciar a instrução e comunicação na organização.
- **Establish Policies, Procedures, etc.** – Estabelecer políticas e procedimentos de suporte à implementação da norma.
- **Implement Management System** – Implementar um sistema de gestão que suporte à melhoria contínua de todos os processos.
- **Final Re-assessment** – Certificar que está tudo conforme a norma para facilitar o próximo passo, a auditoria.
- **Certification Audit** – Auditoria à organização candidata à certificação pela norma ISO/IEC 20000.
- **Maintain Management System** – A certificação é válida apenas por 3 anos. Deverão ser conduzidas auditorias internas anuais para promover uma cultura de melhoria contínua e manter o certificado adquirido.

O processo de certificação está directamente relacionado com o processo de auditoria na medida em que a certificação pressupõe uma inspecção/auditoria para a atribuição do certificado. A certificação demonstra ser um método capaz de aumentar a qualidade da função informática na APP. Muitas empresas no sector privado optam por realizar diversas certificações, nas mais variadas normas, com o objectivo de evoluírem continuamente. O processo de certificação, no domínio da GSI, visa também certificar pessoas com o objectivo de valorizar o seu estatuto profissional no mercado de trabalho. O ITIL e CobiT são exemplos de normas onde é possível obter certificados pessoais de acreditação, com diferentes níveis de especialização.

2.6 Modelos de Maturidade na Gestão de Sistemas de Informação

A Gestão de Sistemas de Informação (GSI) é a actividade responsável pelas tarefas que, numa organização, são necessárias para gerir a informação, os Sistemas de Informação (SI) e a adopção de Tecnologias de Informação e Comunicação (TIC) (Amaral & Varajão, 2007). Os Modelos de Maturidade fornecem aos gestores das organizações um poderoso instrumento para determinarem em que estádio de maturidade se encontram e planearem as acções necessárias para progredirem em direcção a uma maturidade superior (Rocha & Vasconcelos, 2004). Estes, baseiam-se na premissa de que as pessoas, organizações, áreas funcionais, etc. evoluem através de um processo de desenvolvimento em direcção a uma maturidade mais avançada, atravessando um determinado número de estádios distintos (Rocha & Vasconcelos, 2004). Esta definição mantém-se válida nos mais recentes modelos de maturidade. Nolan foi um dos muitos autores que investigou este domínio

e propôs vários modelos. Na sua primeira proposta, em 1973, baseou-se na tecnologia usada e no orçamento em SI como indicadores da maturidade da GSI, usando uma curva em “S”, consistindo em quatro estádios diferentes representados na figura 11:

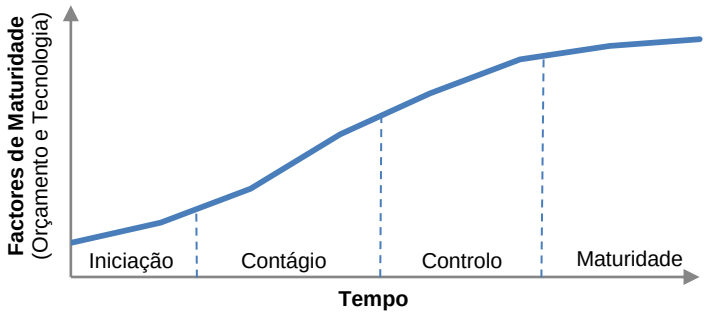


Figura 11 – Modelo de quatro estádios de Nolan (1973) (Rocha & Vasconcelos, 2004).

Em 1979 o mesmo autor verificou que a curva em “S” não representava apenas o crescimento da tecnologia usada e do orçamento em SI mas também a aprendizagem organizacional, embora esta aparecesse num plano secundário (Rocha & Vasconcelos, 2004). Este facto levou ao surgimento do seu modelo de seis estádios representado na figura 12:

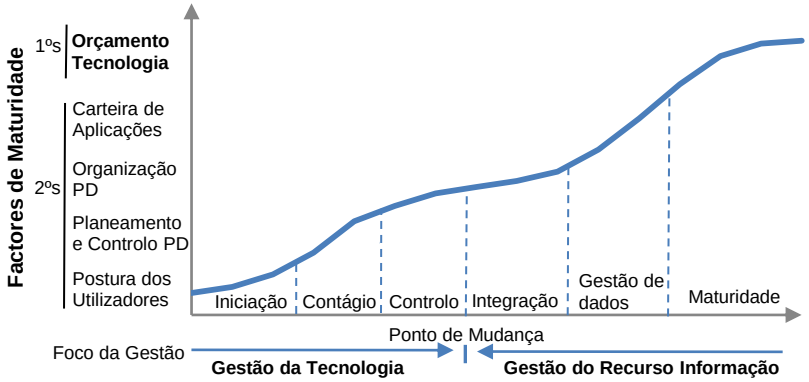


Figura 12 – Modelo de seis estádios de Nolan (1979) (Rocha & Vasconcelos, 2004).

Este modelo foi alvo de várias críticas por parte da comunidade científica (Rocha & Vasconcelos, 2004). Em 1979 surgiu uma outra proposta resultante de alterações consecutivas efectuadas ao antigo modelo de Nolan por vários autores. O modelo encontra-se ilustrado na figura 13:

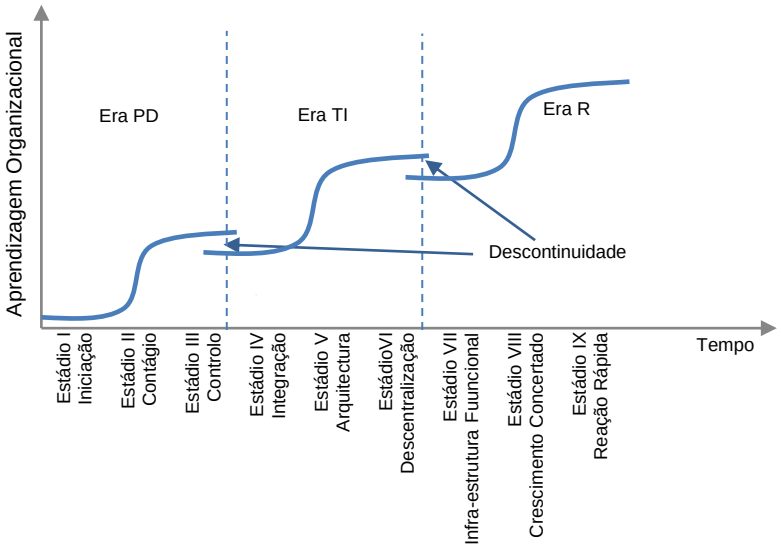


Figura 13 – As três eras de maturidade de Nolan e Mutsaers (1997) (Rocha & Vasconcelos, 2004).

Este modelo descreve as três curvas em "S" como três eras de maturidade da GSI: Processamento de dados (PD), Tecnologia de Informação (TI) e Rede (R), como ilustra a figura 13. Cada "era" é caracterizada por um período de evolução, seguido de um período de estabilidade, terminando com um período de descontinuidade e revolução, antes do início da nova era (Rocha & Vasconcelos, 2004). Os autores Khandelwal e Ferguson sugeriram em 1999, numa proposta inovadora, a combinação do método de Factores críticos de sucesso com o último Modelo de Maturidade de Nolan (Mutsaers, Zee, & Giertz, 1997).

Actualmente, podemos verificar a existência de um vasto número de modelos deste género, bastante mais elaborados, que surgiram como uma evolução, orientada às necessidades actuais, dos modelos apresentados anteriormente.

2.7 Gestão de Serviços Informáticos

Actualmente, e cada vez mais, a informação e a tecnologia que a suporta desempenham um papel crítico em qualquer organização, podendo até dizer-se que são estes os recursos mais valiosos ao serviço de uma organização. No entanto, apesar de tamanha importância, esta tende a não ser reconhecida por todos os *stakeholders* que lidam e interferem com as TI.

O correcto uso das TI poderá trazer vantagens únicas às organizações, elevando a sua performance a patamares dificilmente alcançáveis de outro modo. No entanto, esta corrida constante à modernização organizacional usufruindo das TI comporta elevados riscos, como por exemplo, o nível de dependência crítico que inevitavelmente surgirá entre os processos vitais ao negócio e as TI. Este é um risco constantemente ignorado e que, por isso, acaba por ser experienciado pelas organizações da forma mais infame possível, expondo a sua reputação, imagem e credibilidade. É

neste panorama que surge a necessidade de controlar, monitorizar e validar toda a implementação, uso e manutenção das TI nas organizações.

Frameworks como o ITIL V3, CobiT 4.1 ou o CMMI-SVC fazem parte do dia-a-dia de muitas organizações e são usadas como linhas orientadoras para efectuar uma correcta gestão de todos os serviços informáticos que o funcionamento organizacional pressupõe ou fornece. Apesar de algo distintos, todos estes conjuntos de boas práticas partilham do mesmo objectivo, i.e., permitir um alinhamento constante entre as TI e o negócio que alimenta a organização e fornecer serviços com a qualidade desejada.

2.7.1 ITIL V3

A versão 3 da biblioteca *IT infrastructure Library* (ITIL) foi lançada mundialmente em Junho de 2007 como uma actualização completa da antiga versão 2, publicada no ano 2000. O ITIL consiste num conjunto de linhas orientadoras que especificam qual o caminho a seguir na gestão de serviços de IT com base nas melhores práticas de mercado. Estas linhas orientadores especificam, também, quais os processos necessários para concretizar a definição, planeamento, implementação, execução, monitorização e melhoria contínua na gestão de serviços IT (OGC, 2007).

O ITIL *Complementary Guidance* é também parte integrante do ITIL V3, a par do ITIL V3 Core, e consiste num conjunto de publicações no domínio específico de certas indústrias, tipos de organização, arquitecturas tecnológicas e modelos operacionais (Taylor, Iqbal, & Nieves, 2006).

Actualmente, ITIL é a prática de gestão de serviços de TI mais aceite universalmente (Sahibudin, Sharifi, & Ayat). Ilustra-se na figura 14, o ITIL V3 Core:

Figura 14 – ITIL V3 Core.

O ITIL V3 Core contém 26 processos distribuídos por cinco publicações: *Service Strategy, Service Design, Service Transition, Service Operation* e *Continual Service Improvement*. É especificado, para cada processo, quais os papéis, responsabilidades, objectivos, riscos, etc. associados assim como artefactos bastante úteis e usáveis numa possível implementação. De seguida descreve-se,

sumariamente, as 5 publicações e os respectivos benefícios que uma implementação com sucesso do ITIL poderá trazer às organizações.

Service Strategy

O *Service Strategy* (OGC, 2007) centra-se no desenho, desenvolvimento e implementação da gestão de serviços como um recurso estratégico capaz de suportar o crescimento da organização. O seu grande objectivo passa por definir os objectivos estratégicos da organização.

Service Design

O *Service Design* (OGC, 2007) preocupa-se em desenhar serviços capazes de satisfazer os objectivos de negócio assim como os processos para suportar serviços de TI com grande qualidade. A identificação e gestão de riscos também são incluídas nesta etapa.

Service Transition

O *Service Transition* (OGC, 2007) planeia e gere os recursos de modo a colocar em produção, com sucesso, serviços novos ou alterados, dentro dos prazos, custos e níveis de qualidade acordados. Delinear planos claros e abrangentes que facilitem aos clientes o alinhamento das suas actividades com os planos de transição de serviços também faz parte do *Service Transition.*

Service Operation

O *Service Operation* (OGC, 2007) permite a entrega e suporte de serviços de TI duma forma eficaz e eficiente garantindo a criação de valor para o cliente e fornecedor do serviço.

Continual Service Improvement

O *Continual Service Improvement* (OGC, 2007) consiste no alinhamento e realinhamento contínuo entre os serviços de TI e os requisitos de negócio em constante alteração.

Os objectivos gerais da *framework* ITIL V3, quando aplicada a uma organização, passam por fornecer serviços estáveis, seguros e alinhados com as necessidades dos consumidores e assegurar que os requisitos de negócio da organização são suportados por serviços com a qualidade requisitada, o custo adequado e que tragam valor adicional.

2.7.2 Limitações do ITIL V3

Devido à sua grande aceitação, o ITIL continua a ser alvo de estudos e críticas constantes que discriminam muitas das suas limitações. Enumeram-se, de seguida, algumas dessas limitações:

- O modelo do ciclo de vida proposto não reflecte de forma adequada o ciclo de vida de um serviço (Cruz, 2008);
- Os processos de ITIL possuem inúmeras interdependências e estão em vários estágios do ciclo de vida dos serviços (Cruz, 2008);

- O ITIL possui um carácter generalista, não considerando que cada serviço corresponde a um cenário de implementação diferente (Cruz, 2008);
- O ITIL mistura princípios de gestão de serviços de TI com formas de implementação desses princípios (Cruz, 2008);
- Não existe uma metodologia de implementação do ITL que seja objectiva e esteja bem definida (Cruz, 2008);
- O ITIL encontra-se organizado em torno de processos quando o seu foco está nos serviços (Cruz, 2008);
- O uso de línguagem natural na descrição do ITIL reduz o nível de formalidade durante a sua aplicação, e anula a hipótese de tradução para um modelo de linguagem formal entre outras desvantagens (Hochstein, Zarnekow, & Brenner, 2005);
- O cálculo rigoroso do retorno do investimento das implementações ITIL é de extrema dificuldade (Oliveira, 2009);
- Não possui mecanismos para avaliar e melhorar o estado de maturidade de uma organização (Vliet & Niessink, 1998).

2.7.3 CobiT 4.1

A *framework* CobiT 4.1, *Control Objectives for Information and related Technology*, é um conjunto de boas práticas com foco na gestão de tecnologias de informação. Foi criada em 1992 pela *Information Systems Audit and Control Association (ISACA)* e pelo *IT Governance Institute (ITGI)* (Sahibudin, Sharifi, & Ayat). A sua última versão, 4.1, foi lançada em Maio de 2007. O conjunto de boas práticas foi consensualizado por peritos da área e é focado no controlo, ao contrário do ITIL, cujo maior foco é o da execução (Sahibudin, Sharifi, & Ayat).

CobiT 4.1 é considerada a *framework* de controlo mais apropriada para alcançar o alinhamento entre as TI e os objectivos de negócio levando assim a um *IT Governance* eficaz e eficiente (Ridley, Young, & Carrol, 2004). *IT Governance* é um conceito bem presente na *framework* e define-se como sendo a estrutura de relações e processos a desenvolver, direccionar e controlar os recursos de SI/TI para atingir os objectivos da empresa (Ridley, Young, & Carrol, 2004). A *framework* CobiT 4.1 possui as seguintes características principais (ITGI, 2007):

Orientado a Processos

A *framework* CobiT possui 34 processos de alto nível que cobrem 210 objectivos de controlo detalhados, categorizados em quatro domínios (Fig. 15). Explica-se de seguida quais os objectivos concretos de cada domínio, assim como as características gerais da *framework*:

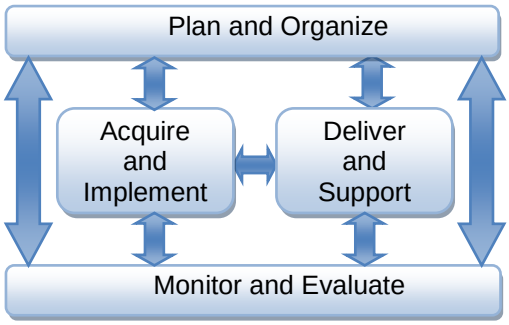


Figura 15 – Os quatro domínios interligados do CobiT (ITGI, 2007).

Plan and Organise – Cobre os aspectos estratégicos e tácticos. Preocupa-se em descobrir qual a maneira mais eficiente de alcançar os objectivos de negócio através do uso de TI. Este domínio contempla, também, a definição da organização assim como a sua estrutura tecnológica.

Acquire and Implement – Este domínio identifica as possíveis soluções de TI, preocupa-se com a sua implementação e posterior integração nos processos de negócio com o objectivo de concretizar a estratégia de TI. As alterações e manutenções dos sistemas existentes também são da responsabilidade deste domínio, garantindo assim um alinhamento constante com os objectivos de negócio.

Deliver and Support **–** Preocupa-se com a entrega de serviços requisitados com a qualidade adequada. Inclui gestão de segurança e continuidade, suporte de serviço para os utilizadores, gestão da informação e das instalações operacionais.

Monitor and Evaluate – Encarrega-se de avaliar a qualidade e comportamento de todos os processos de TI ao longo do tempo assim como o seu alinhamento com os requisitos de controlo. Efectua também a gestão da performance e a monitorização das metodologias de controlo aplicadas pela *framework* CobiT 4.1.

Baseado em Controlos

A *framework* CobiT 4.1 define objectivos de controlo para todos os 34 processos. O termo controlo é definido como sendo um conjunto de políticas, procedimentos, práticas e estruturas organizacionais desenhadas para assegurar que os objectivos de negócio são alcançados, evitando assim resultados indesejados. Os objectivos de controlo são direccionados ao nível de gestão da organização para assim se conseguir um controlo completo de cada processo referente às TI. Estes objectivos de controlo decompõe-se ainda em actividades de controlo, utilizadas para efeitos de auditoria.

Orientado à Avaliação

A *framework* CobiT fornece modelos de maturidade para uma avaliação mais fácil do nível de performance em que a organização se encontra. Existem três tipos de modelos de maturidade, todos baseados no mesmo modelo qualitativo. O primeiro modelo de avaliação permite, para cada um dos 34 processos da *framework* CobiT, perceber em que estado de maturidade se encontra a organização relativamente a esse processo. O segundo modelo de avaliação procura listar, segundo 6 características diferentes, o nível de maturidade que a gestão de processos possui na organização. Por último, é fornecido um modelo de avaliação de controlo interno que demonstra a maturidade da organização relativamente ao uso efectivo e performance de controlos internos.

Estes modelos ajudam a definir qual o nível a que se quer chegar assim como qual a média actual do nível de maturidade das organizações pertencentes ao mesmo sector. Os modelos de maturidade têm uma escala desde não existente (0) até optimizado (5). Através dos modelos de maturidade pode-se perceber qual a situação actual da organização relativamente ao mercado em geral e objectivar quais os pontos mais prioritários a melhorar.

Avaliação de Performance

Existem métricas de avaliação definidas para os objectivos de TI, para os processos e para as actividades. Permite, assim, uma avaliação da performance organizacional desde o mais ínfimo nível até aos objectivos mais genéricos de TI. O CobiT 4.1 fornece objectivos e métricas, ambos definidos em três níveis diferentes:

- Objectivos de TI e métricas definem o que o negócio espera das TI e como medi-lo;
- Objectivos de processos e métricas definem o que deve ser satisfeito pelos processos de TI com o objectivo de suportar os seus objectivos e como medi-lo;
- Objectivos de actividades e métricas estabelecem o que é necessário acontecer no decorrer dos processos para alcançar a performance desejada e como medi-lo;

O CobiT 4.1 tem dois tipos de métricas: *Outcome measures* que indicam se um objectivo foi atingido ou não e só podem ser medidos depois de o *output* ser conhecido e indicadores de performance que são indicadores da probabilidade de um output acontecer ou não.

Business-Focused

A *framework* CobiT 4.1 tem como objectivo principal fornecer a informação que a organização necessita para alcançar os seus objectivos de negócio. Para tal, a organização investe na gestão e controlo de recursos de TI através do uso de um conjunto de processos estruturados que forneçam serviços capazes de entregar a informação requisitada. Desta maneira, consegue-se o alinhamento necessário entre TI e o negócio (Fig. 16).

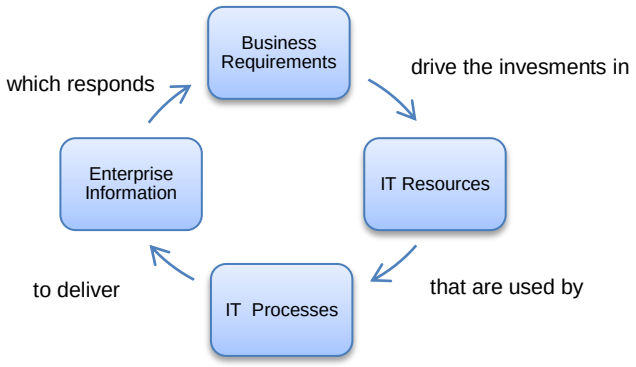


Figura 16 – Princípio básico da *framework* CobiT 4.1 (ITGI, 2007).

Para atingir os objectivos de negócio, a informação da organização deverá satisfazer os seguintes requisitos de negócio que a *framework* CobiT define para a informação: Eficácia, Eficiência, Confidencialidade, Integridade, Disponibilidade, Complacência e Segurança.

Assim, a *framework* CobiT fornece a gestores, auditores, utilizadores de TI e responsáveis dos processos de negócio um conjunto de boas práticas com o objectivo de maximizar os benefícios resultantes do uso de TI nas organizações.

A *framework* CobiT, pelas características descritas, revela-se uma excelente ferramenta para suportar a metodologia proposta descrita na secção 3.

2.7.4 Limitações do CobiT 4.1

A *Framework Cobit* 4.1 apresenta algumas limitações, nomeadamente:

- Existem poucas publicações de origem académica sobre a aplicação da *framework* CobiT (Ridley, Young, & Carrol, 2004);
- A sequência de implementação dos processos de negócio e respectivas actividades assim como a inexistência de artefactos (fluxogramas, etc.) para auxiliar a implementação dos processos de negócio é um ponto fraco do CobiT;
- Toda a *framework* CobiT e processo de auditoria estão bastante focados na indústria dos serviços de TI;
- O uso de linguagem natural na descrição do CobiT reduz o nível de formalidade durante a sua aplicação, e anula a hipótese de tradução para um modelo de linguagem formal entre outras desvantagens (Hochstein, Zarnekow, & Brenner, 2005).

2.7.5 CMMI for Services

O modelo CMMI for Services (CMMI-SVC), V1.2 foi gerado a partir do CMMI V1.2 Architecture and *framework* e define-se como sendo uma colecção de melhores práticas na indústria da gestão de

serviços. Este modelo, CMMI-SVC V1.2 foi publicado em Fevereiro de 2009 e resultou de um esforço conjunto de várias organizações com experiência na indústria dos serviços com o objectivo de adaptar o CMMI a este novo modelo de serviços. Este modelo apresenta-se como o conjunto de melhores práticas na gestão de serviços e que, ao contrário do ITIL V3, não tem como objectivo principal o domínio de TI.

O CMMI-SVC apresenta-se como sendo uma *framework* mais genérica no seu domínio de aplicação convencendo assim os potenciais clientes de que os conceitos abordados por este tipo de *frameworks* são aplicáveis a serviços que não os de TI. É esta a estratégia que o instituto SEI adopta actualmente para ganhar terreno às *frameworks* já instaladas no mercado actual.

O CMMI-SVC contém 24 áreas de processo das quais 16 provêm do CMMI Model Foundation (CMF) e 7 são específicas do domínio dos serviços. O CMMI-SVC foi desenhado sobre o standard CMMI e influenciado pelas *frameworks* ITIL, ISO/IEC 20000, CobiT e ITSCMM.

Existem dois outros modelos baseados no CMF que partilham das mesmas 16 áreas de processo que o CMMI-SVC, assim, para uma organização que já possua o CMMI-DEV ou o CMMI-Acquisition a implementação do CMMI-SVC será de execução menos difícil.

Como já foi referido, o CMMI-SVC é constituído por 24 áreas de processo e faz uso de 3 tipos de componentes para detalhar cada uma das áreas, são eles:

- **Componentes Requeridos** – Descreve o que uma organização deve alcançar para satisfazer uma área de processo;
- **Componentes Esperados** – Descreve o que uma organização deve implementar para obter um componente requerido;
- **Componentes Informativos** – Ajuda as organizações a perceberem os componentes requeridos e esperados.

Os componentes do modelo CMMI são ilustrados na figura 17 e explicados sumariamente de seguida.

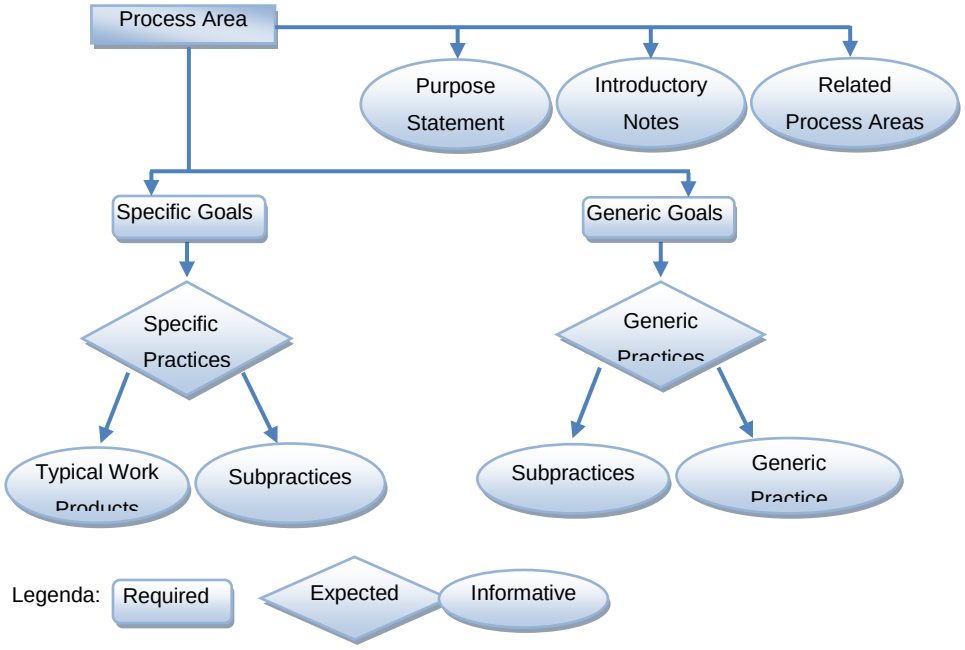


Figura 17 – Componentes do modelo CMMI (SEI, 2009)

Áreas de processo - Uma área de processo é um conjunto relacionado de práticas que, quando implementadas colectivamente, satisfazem objectivos considerados importantes para a melhoria da respectiva área.

Declaração de propósito – Descreve o propósito da área de processo.

Notas introdutórias – Descreve os conceitos gerais de cada área de processo.

Áreas de processo relacionadas – Descreve as relações de alto nível existentes entre as áreas de processo.

Objectivos específicos – Descreve as características únicas que devem estar presentes para satisfazer os requisitos de uma área de processo.

Práticas específicas – Descrição de uma actividade que é considerada importante para a obtenção de um objectivo específico.

Objectivos genéricos – Descrevem características que devem ser satisfeitas em diversas áreas de processo.

Práticas genéricas – Descrição de uma actividade que é considerada importante para a obtenção de um objectivos genérico.

Elaborações das práticas genéricas – Aparece depois de cada prática genérica com o objectivo de orientar a sua aplicação a uma área de processo específica.

Subpráticas – Descrição detalhada de uma prática específica ou genérica e tem como objectivo orientar a sua interpretação e implementação.

***Typical Work Products* –** Um *Typical Work Product* lista o *output* de uma prática específica.

O modelo CMMI-SVC tem a capacidade de avaliar uma organização e classificá-la segundo duas escalas de níveis: níveis de capacidade e níveis de maturidade. Enquanto os níveis de capacidade aplicam-se ao processo de melhoria incremental de uma organização em áreas de processo individuais ou agrupamentos destas, os níveis de maturidade aplicam-se a conjuntos sucessivos de áreas de processo tendo como foco o nível geral de maturidade na organização.

Os objectivos genéricos estão directamente relacionados com o nível de capacidade em que uma área de processo se situa, assim, se uma área de processo satisfizer o objectivo genérico 2, significa que alcançou o nível de capacidade 2.

Para as organizações que optem por usar níveis de maturidade o modelo CMMI-SVC agrupa as 24 áreas de processo por maturidade, ou seja, explicita quais as áreas de processo que precisam de ser implementadas para atingir o nível de maturidade desejado.

Com o objectivo de suportar as organizações que optem pelo uso de níveis de capacidade e de facilitar a sua melhoria incremental, o modelo CMMI-SVC agrupa as 24 áreas de processo em 4 categorias diferentes: *Process Management, Project Management, Service Establishment and Delivery, and Support.*.

2.7.6 Limitações do CMMI-SVC

A *Framework* CMMI-SVC apresenta algumas limitações, designadamente:

- O facto de ser uma *framework* relativamente nova implica a inexistência de material dedicado à sua análise e levanta dúvidas relativamente às suas vantagens;
- O uso de língua natural na descrição do CMMI-SVC reduz o nível de formalidade durante a sua aplicação, e anula a hipótese de tradução para um modelo de linguagem formal entre outras desvantagens, ver (Hochstein, Zarnekow, & Brenner, 2005);
- Fornece pouco material auxiliar ao processo de auditoria.

2.7.7 Análise Comparativa

Após a revisão de 3 *frameworks* na área da GSI pretende-se efectuar uma análise comparativa tendo em conta alguns vectores de comparação e as suas características principais para assim explicitar os pontos fortes e fracos das *frameworks* em questão.

Antes de comparar as *frameworks* em questão, convém perceber quais os seus focos. A figura 18 demonstra a diferença do ITIL V3, CobiT 4.1 e CMMI-SVC relativamente ao seu domínio de aplicação.

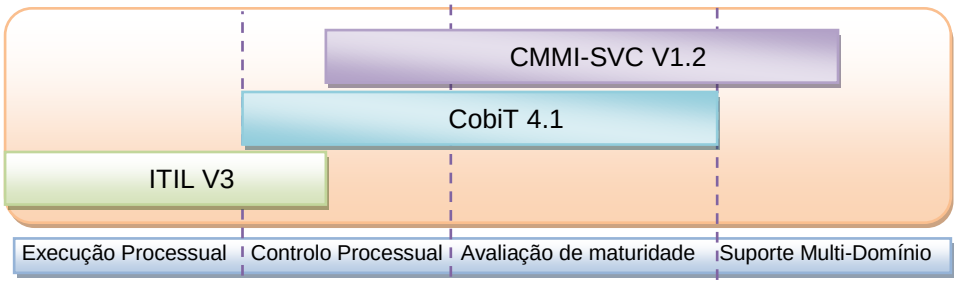


Figura 18 – Domínios de aplicação das diferentes *frameworks.*

O CMMI-SVC, ao contrário do ITIL V3, não tem como objectivo principal a descrição prescritiva de como executar os processos, foca-se antes, em mencionar quais as características que um processo optimizado deverá possuir. O facto de o CMMI-SVC não fornecer detalhes no campo da execução processual e de ser uma *framework* bastante recente contribuíram para que demonstrasse já alguma preocupação em generalizar o domínio de aplicação a outros tipos da indústria de serviços que não a de TI.

O CMMI-SVC demonstra alguma preocupação com o domínio de controlo processual na medida em que são mencionadas as características que um processo optimizado deve possuir. Esta *framework* é ainda completamente orientada à avaliação de níveis de maturidade, no entanto, carece de material auxiliar a esse efeito.

O CobiT 4.1 tem como objectivos principais o controlo de processos e a avaliação dos níveis de maturidade organizacionais. Os mais de 200 objectivos de controlo incutem nesta *framework* uma cultura de controlo processual bastante eficaz. Ao estar orientada a avaliações de maturidade e disponibilizar de imenso material para esse efeito, enquadra-se na perfeição no perfil de *framework* necessário à execução da metodologia proposta descrita na secção 3.

O ITIL V3 fornece um guia detalhado de como implementar os processos, fornece artefactos úteis à concretização dessa implementação e menciona aspectos técnicos no domínio de controlo processual. No entanto, o seu ponto forte, detalhe no campo de execução processual (Sahibudin, Sharifi, & Ayat), encontra-se fora do âmbito da metodologia abordada na secção 3, metodologia essa que pressupõe uma *framework* orientada a avaliações de maturidade.

Pretende-se, nesta secção, comparar o ITIL V3 e o CobiT 4.1 (*framework* a utilizar no decorrer da dissertação, ver secção 3) com mais detalhe devido à característica de complementaridade que ambos apresentam.

Um relatório técnico com um estudo bastante detalhado acerca do mapeamento existente entre o ITIL V3 e o CobiT 4.1 pode ser consultado em (ITGI;OGC, 2008).

Este mapeamento começa por indicar, para cada objectivo de controlo do CobiT 4.1, qual a informação relevante de suporte (Processo, actividade, conjunto de riscos, etc.) que pode ser encontrada no ITIL V3, classificando ainda essa informação como sendo importante ou meramente consultiva.

Seguidamente é efectuada a correspondência entre cada secção e subsecção do ITIL V3 e os objectivos de controlo do CobiT 4.1, não deixando de referir também os processos que lhes

correspondem. A figura 19 resume o suporte que o ITIL V3 concede ao CobiT 4.1 ao nível dos objectivos de controlo (OC):

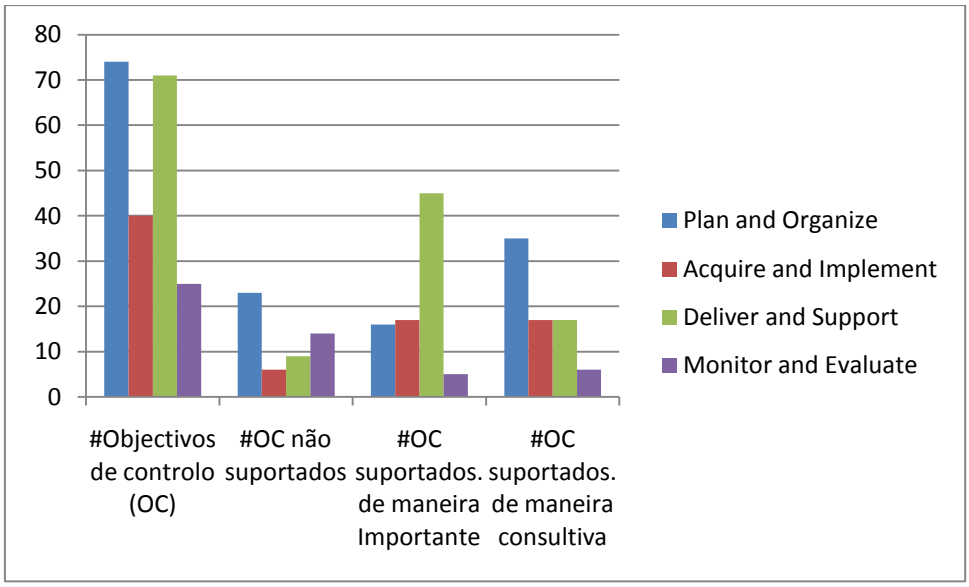


Figura 19 – Mapeamento entre o ITIL V3 e CobiT 4.1.

Informa-se ainda que:

- Apenas 2 processos CobiT 4.1 não têm qualquer suporte no ITIL V3;
- 80% dos processos CobiT 4.1 têm pelo menos 50% dos seus objectivos de controlo suportados pelo ITIL V3;
- Apenas 24% dos objectivos de controlo não são suportados pelo ITIL V3.

Este mapeamento demonstra o elevado grau de semelhança que as *framework* ITIL V3 e CobiT 4.1 apresentam nos 4 domínios analisados e vem reforçar a ideia de que o ITIL V3 pode "implementar" o CobiT 4.1.

Como já foi referido anteriormente na secção 2.7.3, o CobiT 4.1 tem dois tipos de indicadores para a avaliação da performance: *Outcome measures* e indicadores de performance. O CobiT 4.1 fornece estes indicadores conjuntamente com os objectivos específicos das actividades, dos processos e das TI de uma forma alinhada e simples.

O ITIL V3 fornece, para cada processo, um conjunto de Métricas, Desafios, riscos e factores críticos de sucesso. No entanto, não é explícito quais as suas relações directas com os objectivos de negócio. Este aspecto está melhor detalhado no CobiT 4.1.

Já o CMMI-SVC apresenta um conjunto de objectivos específicos e genéricos directamente relacionados com o mecanismo de *benchmarking* usado por esta *framework.*

O CobiT 4.1 fornece indicações claras sobre como classificar cada processo, o uso de objectivos de controlo e o estado de gestão de processos segundo um nível de maturidade através de modelos de maturidade. O ITIL não fornece metodologias de avaliação do nível de maturidade das organizações. No entanto, um dos pontos fortes do ITIL, devido ao seu foco na execução processual,

é a maneira como descreve os processos e as suas actividades com artefactos bastante úteis e usáveis numa possível implementação (Sahibudin, Sharifi, & Ayat).

3 Metodologia Proposta

Com o objectivo de avaliar a maturidade da função informática na APP, os autores irão auditar 3 DI. Pretende-se, deste modo, validar as hipóteses abaixo descritas e analisar a correlação existente entre as variáveis nível de maturidade, dimensão e qualidade dos serviços.

A metodologia proposta para a abordagem ao problema de Tese apresentado consistirá em três fases, representadas na figura 20.

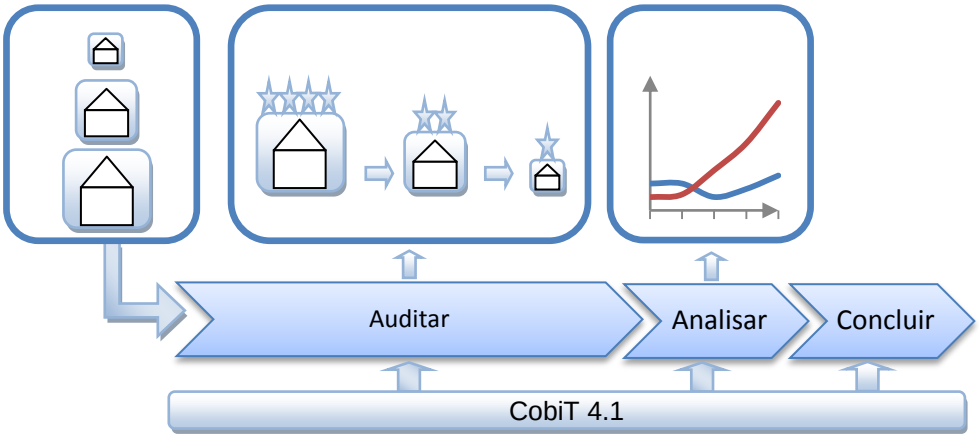


Figura 20 – Representação genérica da metodologia de solução.

Esta metodologia contempla a realização de três casos de estudo em conformidade com a metodologia de investigação descrita na secção 1.4. Após finalizados os casos de estudo serão analisadas todas as informações recolhidas.

- **Auditar** – Auditorias CobiT a 3 OP de dimensão pequena, média e grande para levantamento do estado *as-is.* Para melhor validar a investigação, os DI de diferentes dimensões foram escolhidos tendo em conta a sua representação mediana no tamanho que possuem. Ou seja, o DI de pequena dimensão, por exemplo, representa a média daquilo que é o universo total deste tipo de DI na APP;
- **Analisar** – Análise dos dados adquiridos de forma a provar se existe uma má GFI na APP. Avaliar a correlação existente entre as variáveis nível de maturidade, dimensão e qualidade dos serviços num DI;
- **Concluir** – Explicitar as conclusões retiradas de todo o processo de análise.

Com a metodologia proposta pretende-se validar as seguintes hipóteses:

- Os DI de pequena dimensão existentes na APP têm uma baixa maturidade e má qualidade nos serviços que prestam.

- Existe uma falta de conhecimento acentuada das melhores práticas internacionais na APP, com especial enfoque nos DI de pequena dimensão.
- O nível de maturidade está, por norma, directamente relacionado com a dimensão do DI e com a qualidade dos serviços prestados.

Com o objectivo de facilitar a compreensão do problema abordado, define-se o seguinte indicador:

1. A= VAN / C

Legenda:

QS – Qualidade do Serviço;

A – Rácio de valor acrescido ao negócio e custos;

C – Custos;

VAN – Valor acrescido ao negócio;

As variáveis QS e VAN são dificilmente calculáveis e tão pouco directamente relacionáveis no mesmo eixo com a variável Custo, no entanto, este é apenas um exemplo conceptual e tem um fim ilustrativo. A variável VAN pode ser encarada como uma variável que mede as mais-valias que um DI tem para com o negócio, como por exemplo, vantagem competitiva adquirida. Assume-se que a variável custo aumenta com o nível de maturidade.

De seguida apresenta-se um gráfico, na figura 21, que procura conjugar a relação entre estas variáveis para melhor explicitar o problema.

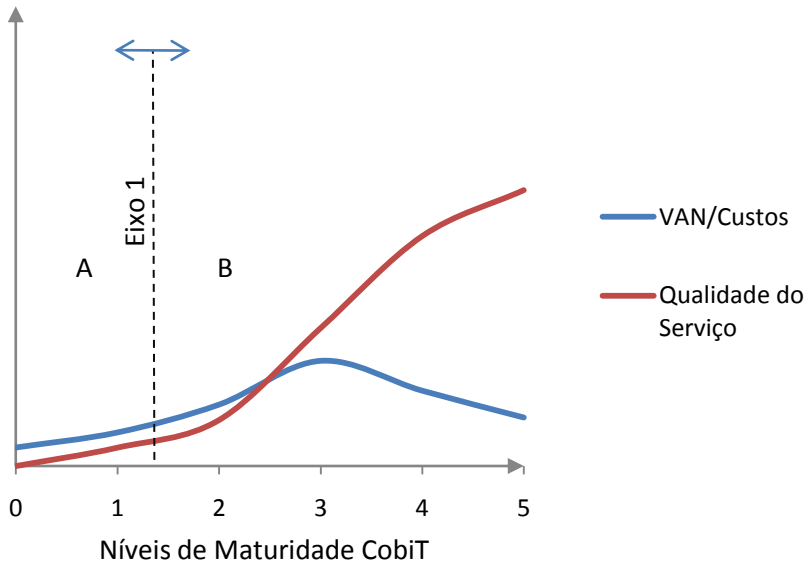


Figura 21 – Relação Maturidade Qualidade dos Serviços prestados.

Este gráfico ilustra que existe uma ligação directa entre nível de maturidade e qualidade dos serviços prestados (Cumps, Viaene, & Dedene, 2006). Indica também que apesar de os custos de um DI aumentarem com o nível de maturidade, o aumento do valor acrescido ao negócio obtido será superior, até um certo nível.

O eixo que divide a área do gráfico em duas zonas encontra-se numa posição meramente de referência e não será definido nesta investigação. Serve apenas para demonstrar que existe um mínimo aceitável a partir do qual os DI merecem existir. No decorrer da dissertação tentar-se-á provar que os DI de pequena dimensão situam-se atrás do eixo 1, ou seja, encontram-se com uma fraca qualidade de serviço e uma relação VAN/custos baixa.

A escolha da *framework* CobiT 4.1 para suportar a execução da investigação deve-se aos seguintes factores:

- A Inspecção Geral de Finanças efectua, com alguma regularidade, auditorias CobiT a organismos públicos (OP). Será então mais conveniente optar pela mesma *framework* para assim facilitar o *commitment* dos OP em todo o processo e promover uma comparação válida.
- Ser uma *framework* bastante focada no domínio de avaliação de maturidade, tal como referido na secção 2.7.7.
- Apresenta características de complementaridade relativamente à *framework* ITIL V3, habilitando assim a presente Tese de possíveis aplicações futuras mais práticas.

4 Metodologia de Auditoria

Ao longo da dissertação de Mestrado foi aplicada a metodologia de solução descrita na secção 3. Foram realizadas auditorias a três DI da APP de dimensões pequena, média e grande. Os resultados foram depois analisados de modo a extrapolar as conclusões pretendidas.

Ao longo da subsecção seguinte será descrita a metodologia de auditoria seguida que se baseia na metodologia descrita em (ITGI, 2007) e resumida na secção 2.4.

A metodologia de auditoria seguida consiste em quatro etapas distintas: Planeamento, *Scoping*, Execução e Conclusão. De seguida, explicar-se-á detalhadamente a metodologia seguida para as auditorias efectuadas.

Figura 22 – Metodologia de auditoria.

4.1 Planeamento

A fase de planeamento pretende estabelecer o primeiro contacto com a entidade auditada e delinear o plano genérico da auditoria, esta fase possui as seguintes actividades:

- **Estabelecer objectivos –** Esta actividade serve como ponto de partida para toda a auditoria e consiste numa primeira reunião com o CIO ou equivalente, onde se definem as primeiras restrições de actuação da auditoria e os objectivos de parte a parte.
- **Gerir Recursos –** Esta actividade pretende maximizar a performance de toda a auditoria. Sabendo que a auditoria é um processo que consome bastante tempo a todos os interlocutores, tenta-se geri-la da melhor forma possível para eliminar picos de trabalho.

4.2 Scoping

A fase de *scoping* tem como objectivo principal enquadrar a *framework* CobiT 4.1 no contexto operacional do DI auditado. Pretende delimitar o âmbito da auditoria através de um conjunto de avaliações de alto nível. Esta fase possui as seguintes actividades:

- **Efectuar análise de risco de alto nível –** Consiste num conjunto de perguntas para todos os 34 processos da *framework* CobiT 4.1. Este questionário, presente no anexo I, é preenchido na presença do auditor, pelo CIO ou função com *know how* equivalente. Com este questionário pretende-se:

- Perceber quais os processos de negócio mais importantes para o DI e qual a sua performance, adquirindo assim uma noção no domínio do risco;
- Identificar os processos de negócio que não serão auditados por não se enquadrarem no contexto operacional do DI;
- Identificar, caso exista, a pessoa *accountable* pelo respectivo processo de negócio;
- Identificar os processos de negócio que já foram auditados;
- Avaliar a formalidade dos processos de negócio.

- **Identificar os processos a incluir no âmbito da auditoria –** Durante uma reunião com o CIO e com base no questionário anteriormente realizado, é efectuado o *scoping* dos processos de negócio a incluir na auditoria.
- **Avaliação de alto nível da maturidade actual –** Para os processos incluídos no âmbito da auditoria, identificar qual o nível de maturidade associado através de um conjunto de questionários mais aprofundados. No anexo II encontra-se uma exemplificação (apenas para os níveis de maturidade 0 e 5) deste questionário para o processo PO1 – Plano Estratégico de TI.
- **Seleccionar os componentes de TI –** Escolher os recursos, e.g., aplicação, informação, infra-estrutura ou pessoas, a incluir no *scope*. No âmbito da presente investigação foram escolhidos dois ou três SI como componentes de TI a auditar.
- **Identificar processos transversais –** Nesta actividade pretende-se identificar os processos transversais à organização, ou seja, que não apresentam variações significativas SI a SI. Assim, os processos transversais, e.g., Gestão do Risco ou Gestão do Investimento em TI, têm como interlocutor o CIO ou uma outra função com *know-how* específico do processo. Os restantes processos são da responsabilidade dos interlocutores nomeados para cada SI e serão auditados SI a SI, ver figura 23.
- **Seleccionar os objectivos de controlo –** Eliminar os objectivos de controlo que, caso não sejam atingidos, não tenham um efeito material e visível no contexto operacional do DI.

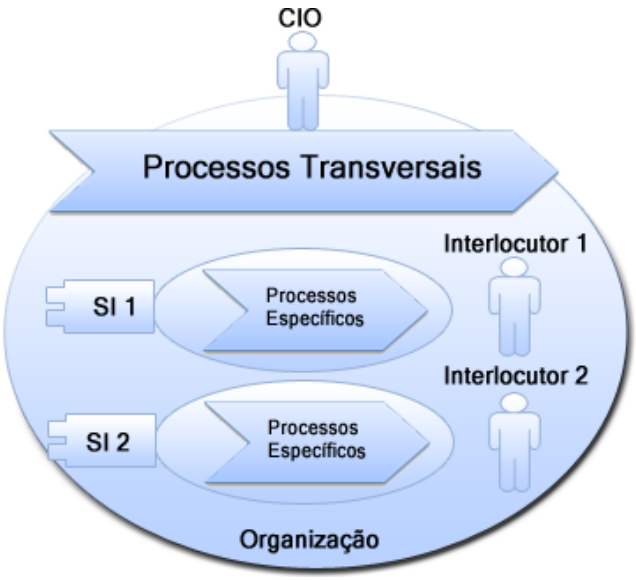


Figura 23 – Exemplo de *output* da fase scoping.

Na figura 23 está ilustrado um exemplo de *output* da fase *scoping.* Para o exemplo dado, os processos transversais são da responsabilidade do CIO existindo ainda o interlocutor 1 responsável pelo SI 1 e o interlocutor 2 responsável pelo SI 2.

4.3 Execução

Após concluída a fase de *scoping*, o auditor possui as seguintes informações e artefactos:

- Uma avaliação de maturidade de alto nível do as-is organizacional;
- Os componentes de TI a auditar definidos, i.e., dois ou três SI mais um conjunto de processos transversais e específicos;
- Os interlocutores responsáveis pelos SI e pelos processos transversais definidos.

A fase de execução consiste numa avaliação de maturidade rigorosa, seguindo as ferramentas disponibilizadas para o efeito no âmbito da *framework* CobiT 4.1. Como já foi referido na secção 2.7.3, a *framework* CobiT 4.1 possui a estrutura ilustrada na figura 24. A actividade de controlo constitui o nível mais ínfimo da estrutura *framework* CobiT 4.1.

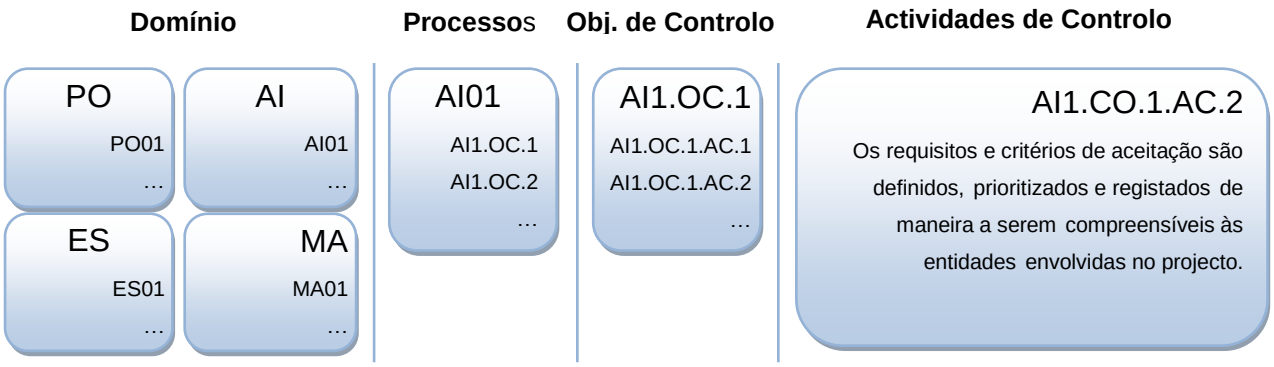


Figura 24 – Estrutura da *framework* CobiT 4.1.

No anexo III encontra-se um exemplo do manual de controlo interno da *framework* CobiT 4.1 para os objectivos de controlo 2 e 3 do processo PO1.

Nesta fase, os interlocutores nomeados recolhem as evidências que satisfaçam o nível de exigência presente na descrição textual das actividades de controlo que lhes foram atribuídas.

As evidências recolhidas são analisadas pelo auditor e, consoante a sua qualidade/adequabilidade à respectiva actividade de controlo, esta será classificada como:

- **Efectiva** – As evidências satisfazem a exigência da actividade de controlo.
- **Parcialmente Efectiva** – As evidências satisfazem parcialmente a exigência da actividade de controlo ou existem indícios de que a actividade de controlo será satisfeita num futuro próximo.
- **Inefectiva** – Não existem evidências que comprovem a actividade de controlo ou as evidências existentes não são válidas.

Uma evidência tem como objectivo comprovar a aplicação/execução das actividades de controlo e pode tomar várias formas, e.g., um print screen ou uma entrevista, ver anexo IV. As actividades de controlo contarão para o resultado final com um peso de 5, 2.5 e 0 para classificações de Efectiva, Parcialmente Efectiva e Inefectiva, respectivamente.

4.4 Conclusão

A fase de conclusão consiste no agrupamento de toda a informação recolhida e na produção de um relatório de auditoria. No relatório é apresentada toda a informação após análise, assim como um conjunto de sugestões de melhoria para cada processo auditado.

5 Resultados Obtidos

Com o decorrer das auditorias foram recolhidas informações sobre a gestão da função informática nos três departamentos informáticos da APP. Nesta secção será descrita e enumerada toda a informação recolhida ao longo das três experiências. Por fim, os resultados serão discutidos de forma crítica com o objectivo de extrapolar e interpretar toda a informação recolhida.

5.1 Auditoria ao DI de Pequena Dimensão

A auditoria ao DI de pequena dimensão foi efectuada, na totalidade, pelo autor. Assim, foi possível recolher informação nas diferentes fases da auditoria e seguir, com rigor, a metodologia proposta na secção 3. O resultado da auditoria foi de 0.1 na escala de 0 a 5 da *framework* CobiT 4.1. A tabela seguinte sumariza informações respectivas ao DI/OP e aos resultados da auditoria realizada:

Orçamento TI	290 000 €
Duração da auditoria	2 Meses
Nº de colaboradores TIC	6
Nº de colaboradores total	62
Processos auditados	15
Processos Transversais	10
Processos Específicos	5
SI auditados	2
Percepção do CIO sobre o estado da GFI	2 (0 – 5)
Estado real da GFI do DI	0.1 (0 – 5)
Percentagem de processos formais	0%
Percentagem de processos indicados como formais pelo CIO	25%

Tabela 2 - Informações do DI de pequena dimensão.

Descreve-se, de seguida, o trabalho realizado durante as 4 fases da auditoria.

5.1.1 Planeamento

A fase de planeamento decorreu numa primeira reunião com o CIO do DI, onde foram estabelecidos os objectivos de parte a parte. A metodologia foi ilustrada e explicada com detalhe e após algum *brainstorming* sobre a gestão de recursos, ficou também acordado que os colaboradores do DI que actuassem como interlocutores teriam 20% do seu tempo alocado ao processo de auditoria.

5.1.2 Scoping

Como primeira actividade da fase *scoping* efectuou-se uma análise de risco de alto nível. O questionário que suporta a análise encontra-se no anexo I. De seguida enumeram-se alguns dados extrapolados desse questionário, para o DI de pequena dimensão:

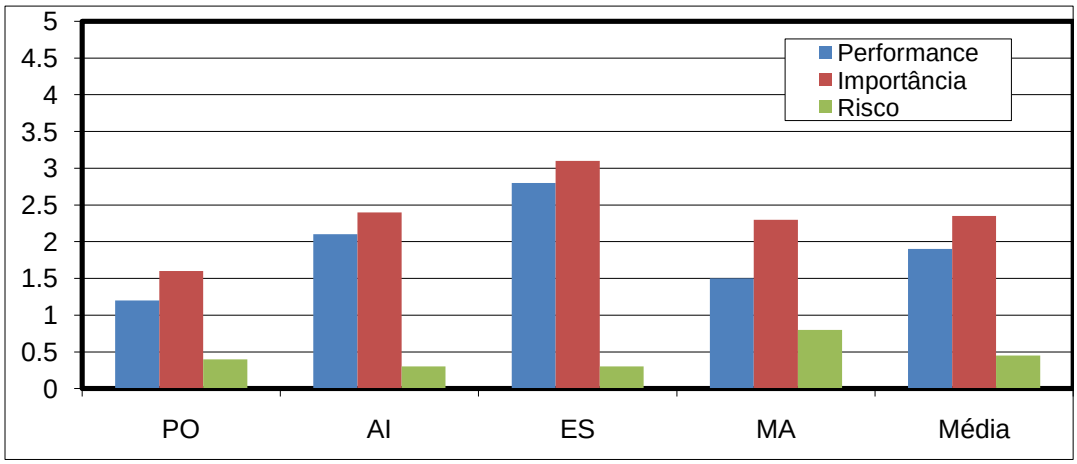


Figura 25 – Relação Performance/Importância do DI de pequena dimensão.

Através da figura 25 é possível ter uma noção mais aprofundada dos domínios que mais necessitam de uma intervenção rápida. Apesar de a performance estar claramente inflacionada, 1.9 face os reais 0.1, a diferença relativa entre a performance e importância, denominado risco, traduz-se como sendo uma métrica mais precisa e fiável.

Com base nas informações obtidas com o primeiro questionário, foi efectuado o *scoping* ao nível dos processos, de onde resultou a seguinte selecção:

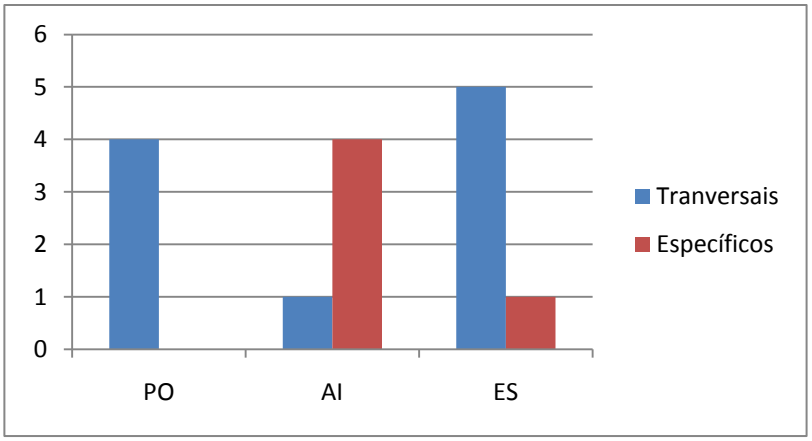


Figura 26 – *Scoping* ao nível dos processos.

Note-se que o domínio de Monitorização e Avaliação ficou excluído após esta fase pela falta de qualquer tipo de prática ou procedimento em vigor que justificasse uma auditoria. Não havia, portanto, qualquer indício de práticas de monitorização ou avaliação da função informática.

As restantes informações extrapoladas do primeiro questionário encontram-se ilustradas na figura 27:

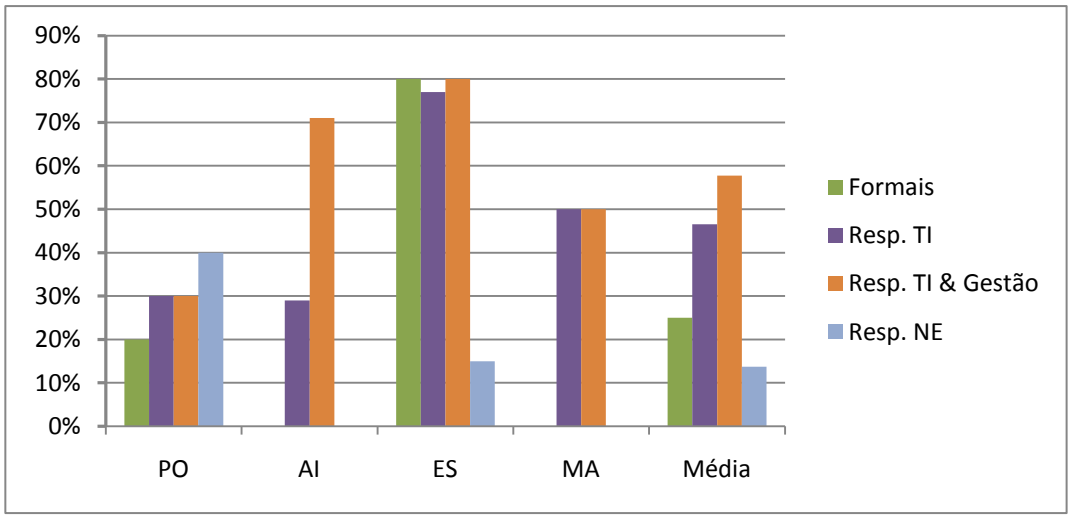


Figura 27 – Responsabilidade e Formalidade dos Processos.

Do gráfico presente na figura 27 retiram-se as seguintes informações:

- O domínio de planeamento e organização é o domínio com mais processos (40%) sem área responsável atribuída.
- O domínio de entrega e suporte é onde a gestão/administração tem mais responsabilidades, onde participa activamente em 80% dos processos.
- 25% dos processos da *framework* CobiT 4.1 foram considerados como formais pelo CIO.
- De um modo geral e olhando apenas para este questionário, parece haver um alinhamento razoável entre a gestão e as TI, com uma participação activa em cerca de 60% dos processos.

Ainda com base no questionário, verificou-se que nenhum processo foi alvo de auditoria ou possui alguém *accountable*. Não existe, portanto, a implementação do conceito *accountable* na organização.

Com base na metodologia descrita na secção 4, o próximo passo consistiu numa avaliação de alto nível da maturidade actual. O questionário que suportou esta avaliação encontra-se exemplificado no anexo II. O objectivo deste questionário é, para os processos seleccionados, perceber qual o nível de maturidade em que a organização se encontra, ou, pelo menos, em que o CIO julga estar. No gráfico seguinte ilustra-se a probabilidade que a organização tem de estar em cada nível de maturidade.

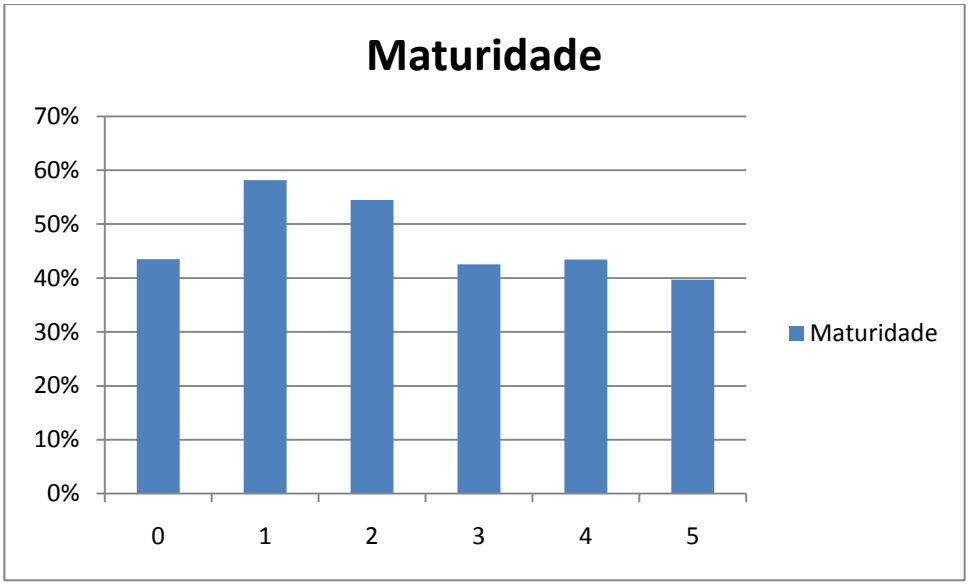


Figura 28 - Resultado da avaliação de maturidade de alto nível.

A leitura correcta deste gráfico informa que a organização encontra-se no nível 1 de maturidade, com alguma probabilidade de avançar para o nível 2. No entanto, os resultados estão inflacionados, visto que a organização tem uma probabilidade de 40% de se encontrar no nível 5 de maturidade e de, na realidade, encontrar-se actualmente no nível 0. Ainda sobre o questionário anterior, ilustra-se na figura 29 por processo e na figura 30 por domínio, o nível de maturidade alcançado:

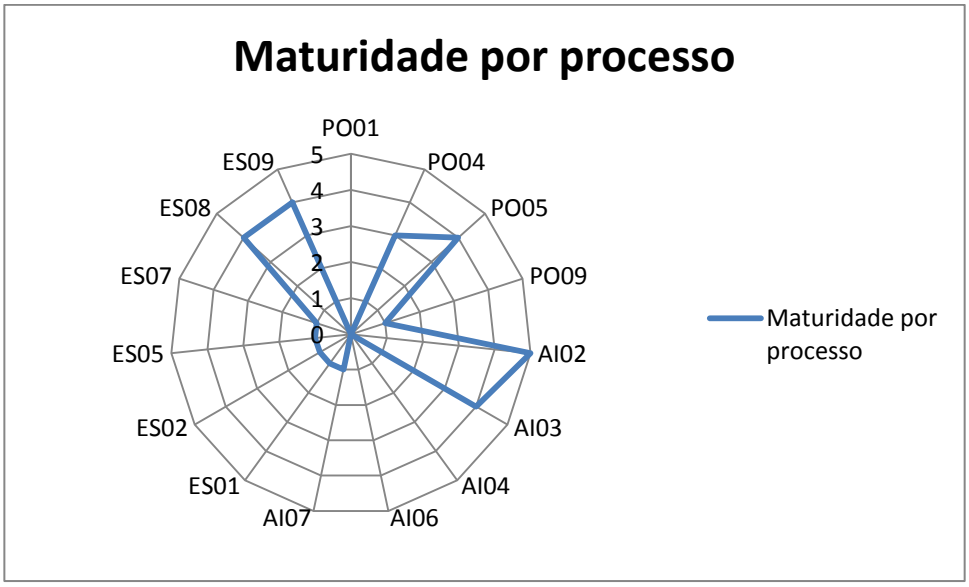


Figura 29 – Maturidade por processo após avaliação de alto nível.

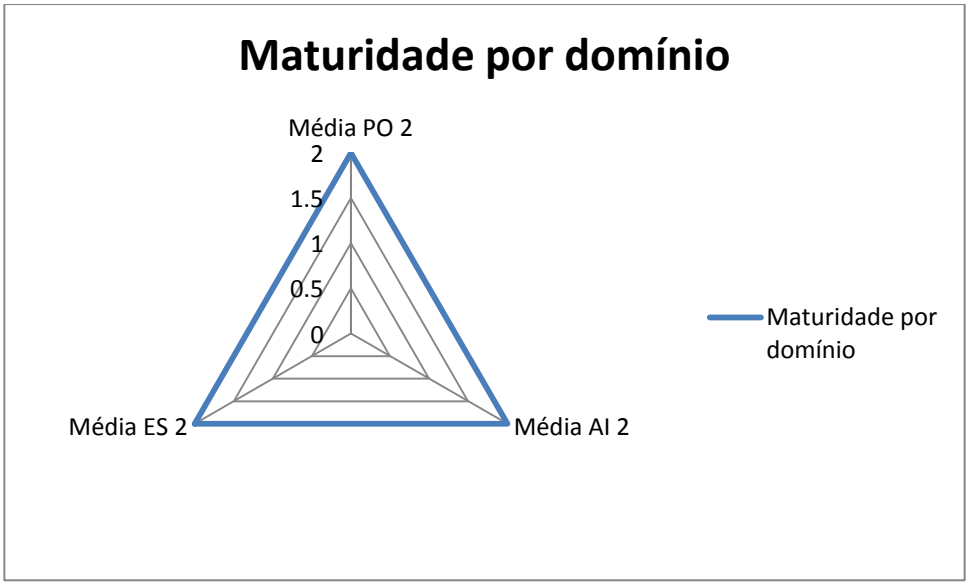


Figura 30 – Maturidade por domínio após avaliação de alto nível.

5.1.3 Execução

Na fase de execução foram avaliadas cerca de 370 actividades de controlo, distribuídas pelos 15 processos alvo de auditoria. Todos os interlocutores tinham como missão recolher o número máximo de evidências que pudessem de alguma forma comprovar a efectividade das actividades de controlo analisadas. Os processos transversais tiveram como interlocutor o CIO, já os dois SI escolhidos tiveram como interlocutores três outros colaboradores do DI. Na figura 31 apresenta-se o gráfico que resume os resultados finais, por domínio, da auditoria pormenorizada ao DI de pequena dimensão.

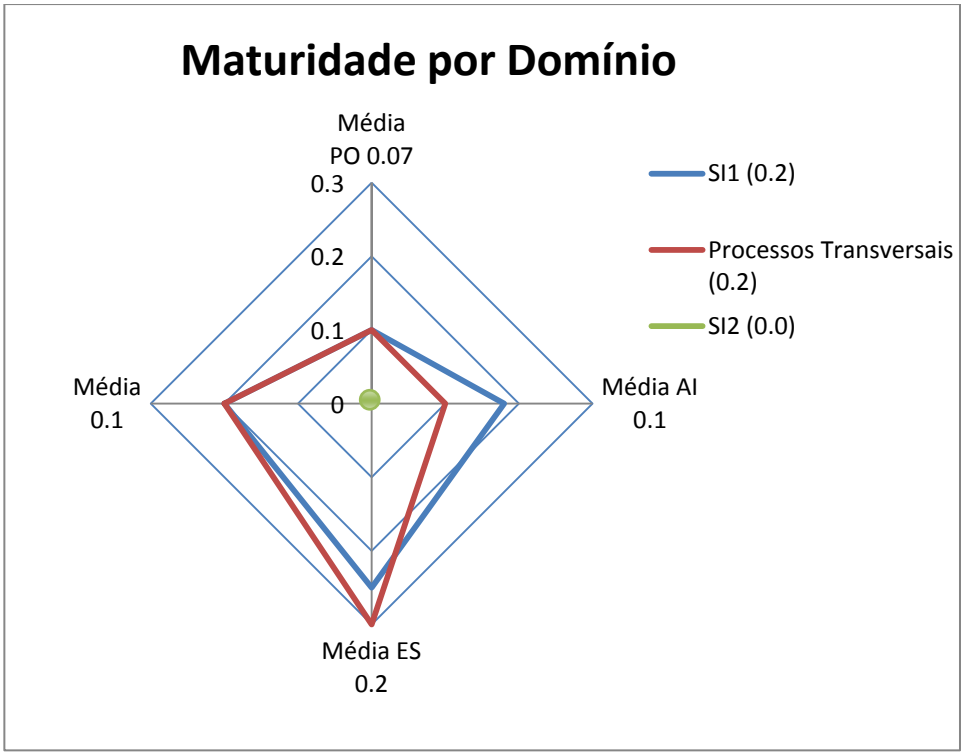


Figura 31 – Maturidade real por domínio.

De seguida, na figura 32, apresenta-se o gráfico que ilustra a maturidade real por processo.

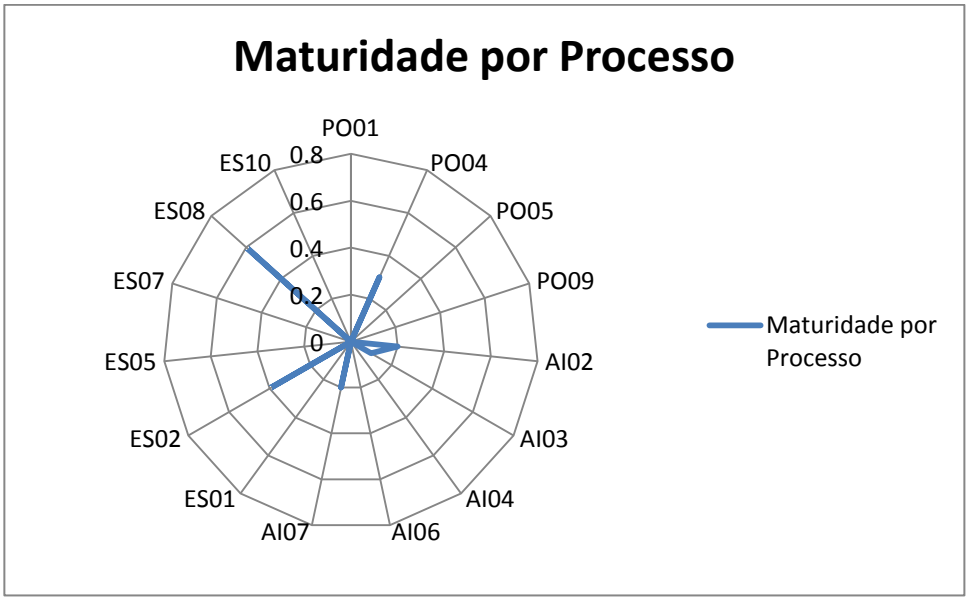


Figura 32 – Maturidade real por processo.

Os processos foram ainda classificados segundo 6 vectores de maturidade presentes na *framework* CobiT 4.1:

- **Awareness and Comunication** – Comunicação e consciência organizacional do processo.
- **Policies, plans and procedures** – Nível de formalização.

- **Tools and automation** – Nível de automação.
- **Skills and expertise** – Nível de qualificação dos colaboradores.
- **Responsability and accountability** – Nível de responsabilização.
- **Goal setting and measurement** – Nível de estabelecimento de objectivos, monitorização e avaliação.

A figura 33 ilustra essa classificação segundo os 6 vectores de maturidade:

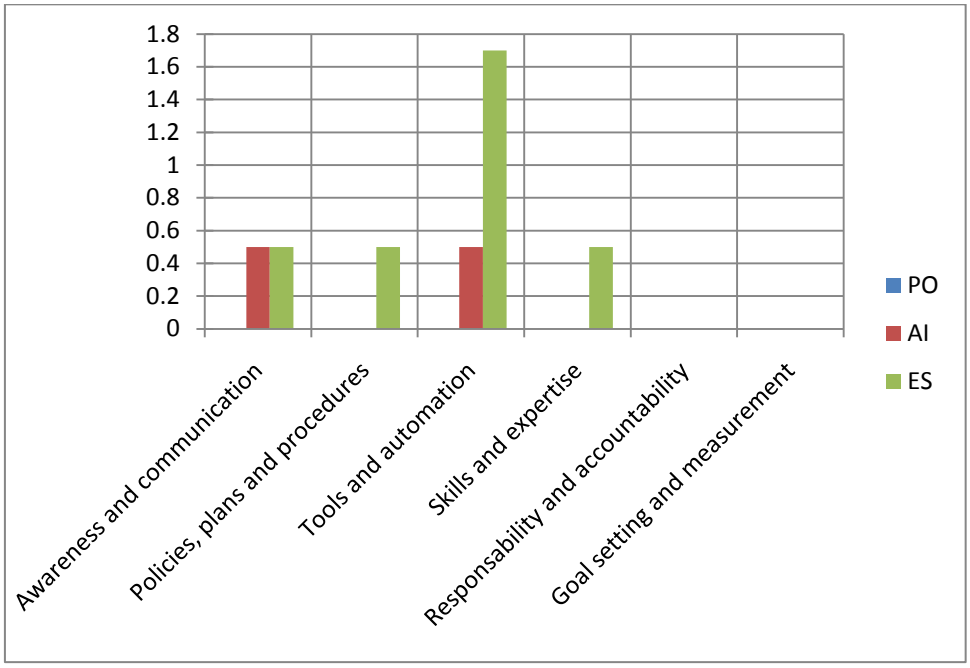


Figura 33 – Classificação segundos os seis vectores de maturidade.

5.1.4 Conclusão

A fase de conclusão consistiu na redacção de um relatório de auditoria contendo toda a informação resultante da auditoria com o objectivo de o validar e apresentar junto da entidade auditada. Este relatório, para além de conter muita da informação mencionada anteriormente, contém ainda um conjunto de sugestões de melhorias aplicáveis ao DI. Assim, espera-se que a entidade auditada fique com uma noção mais aprofundada do estado real da GFI e que possua as direcções a seguir para evoluir o seu nível de maturidade. Neste DI, pelo facto de a organização não estar sequer orientada a processos, foi sugerido como ponto crítico de melhoria a implementação do processo PO4 - Definição dos Processos de IT, Organização e Relacionamentos. Após comunicados e validados todos os resultados, o CIO do DI mostrou-se algo surpreendido pelo resultado obtido: "O trabalho desenvolvido vai ser muito útil para justificar a necessidade de implementação de um plano estratégico para a informática junto do Conselho Directivo, para além de ser útil na identificação dos pontos fracos e oportunidades de melhoria. Fico apreensivo pelo facto de ainda estarmos tão longe de atingir os níveis que deveríamos ter, no entanto vamos a pouco e pouco procurar melhorar."

Após concluído todo o processo, foi ainda requisitado ao CIO que indicasse o nível de maturidade que espera alcançar a curto e a longo prazo. A figura seguinte resume os principais resultados extraídos da auditoria:

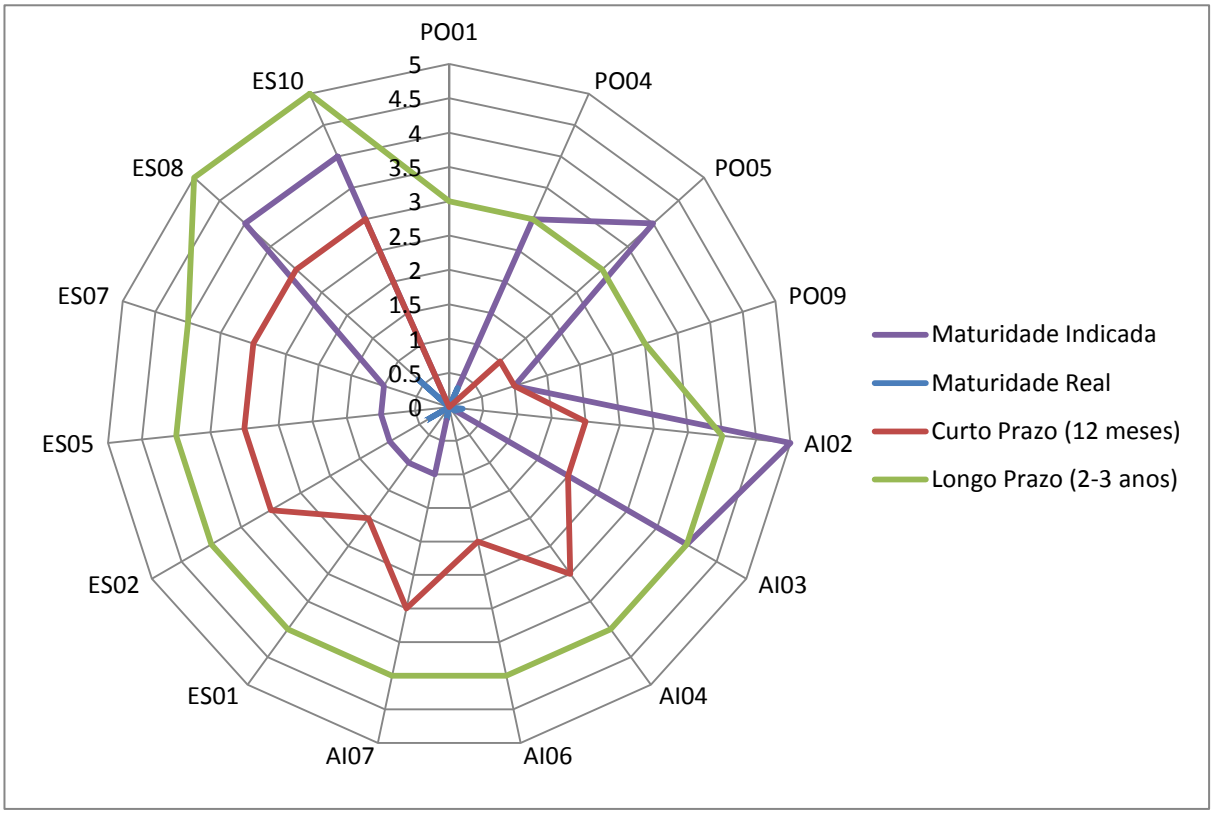


Figura 34 – Principais resultados da auditoria ao DI de pequena dimensão.

5.2 Auditoria ao DI de Dimensão Média

O resultado da auditoria foi de 2.3 na escala de 0 a 5 da *framework* CobiT 4.1. A tabela seguinte sumariza informações respectivas ao DI e aos resultados da auditoria realizada:

Orçamento TI	7 400 000
Duração da auditoria	2 Meses
Nº de colaboradores TIC	26
Nº de colaboradores total	151
Processos auditados	5
Processos Transversais	1
Processos Específicos	4
SI auditados	2
Estado real da GFI do DI	2.3 (0 – 5)

Tabela 3 – Informações do DI de dimensão média

Explica-se, de seguida, o trabalho realizado durante as 4 fases da auditoria.

5.2.1 Planeamento

A fase de planeamento decorreu numa primeira reunião com o CIO do DI, onde foram estabelecidos os objectivos de parte a parte. A metodologia foi ilustrada e explicada com detalhe.

5.2.2 Scoping

Como primeira actividade da fase *scoping* efectuou-se uma análise de risco de alto nível. O questionário que suporta a análise encontra-se no anexo I. De seguida enumeram-se alguns dados extrapolados desse questionário, para o DI de dimensão média:

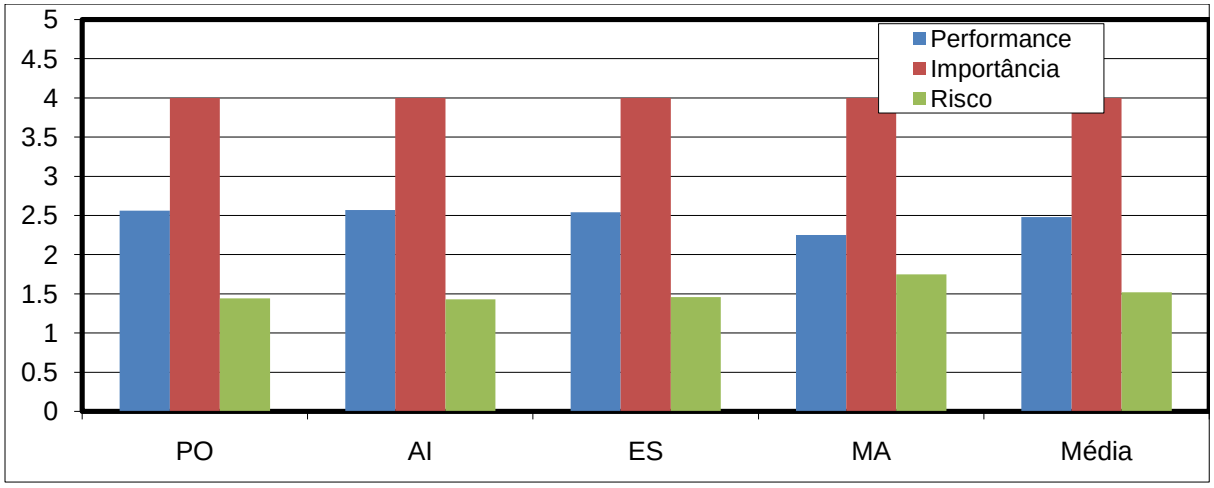


Figura 35 – Relação Performance/Importância do DI de pequena dimensão.

Dado que as respostas foram praticamente idênticas para os 4 domínios existentes, através da figura 35 é apenas possível perceber que o domínio de MA é o que possui mais risco. Pode-se também inferir que o CIO considera que a performance está abaixo do expectável em todos os domínios. Devido aos escassos recursos disponíveis à execução da auditoria, o *scoping* desta auditoria ficou mais limitado:

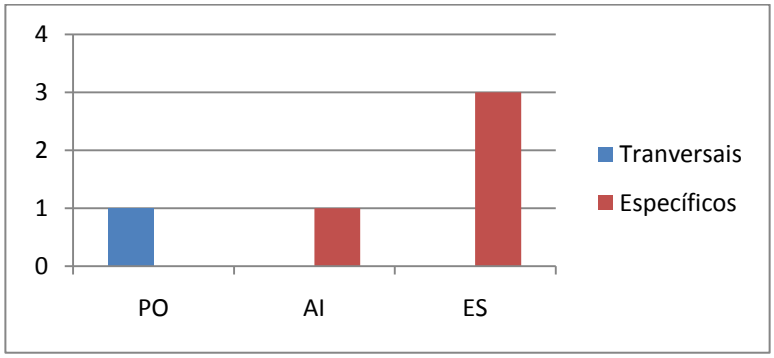


Figura 36 – *Scoping* ao nível dos processos.

Note-se que o domínio de Monitorização e Avaliação ficou excluído após esta fase pelas mesmas razões do DI de pequena dimensão, i.e., não existir práticas em vigor que justificassem uma auditoria.

Com base na metodologia descrita na secção 4, o próximo passo consistiu numa avaliação de alto nível da maturidade actual. O questionário que suportou esta avaliação encontra-se exemplificado no anexo II. O objectivo deste questionário é, para os processos seleccionados, perceber qual o nível de maturidade em que a organização se encontra, ou, pelo menos, em que o CIO julga estar. O gráfico indica qual a probabilidade de a organização se situar em cada nível de maturidade CobiT. Durante esta auditoria foi possível obter estas respostas apenas para dois processos, ES08 e ES010. Ilustra-se na figura 37 o resultado obtido para o processo ES08:

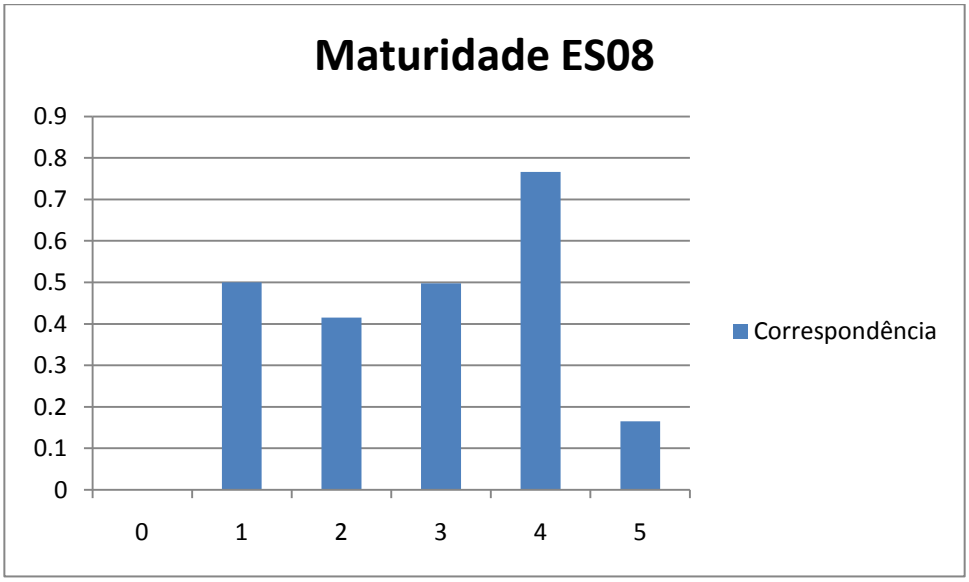


Figura 37 – Resultado da avaliação de maturidade alto nível para o processo ES08.

A leitura correcta deste gráfico informa que a organização encontra-se no nível 4 de maturidade para o processo ES08. Pode-se verificar que, neste caso e ao contrário do DI de pequena dimensão, os resultados não estão inflacionados visto que a maturidade real deste processo foi de 3.8.

5.2.3 Execução

Na fase de execução todos os interlocutores tinham como missão recolher o número máximo de evidências que pudessem de alguma forma comprovar a efectividade das actividades de controlo analisadas. Na figura 38 apresenta-se o gráfico que resume os resultados finais por domínio da auditoria pormenorizada ao DI de dimensão média.

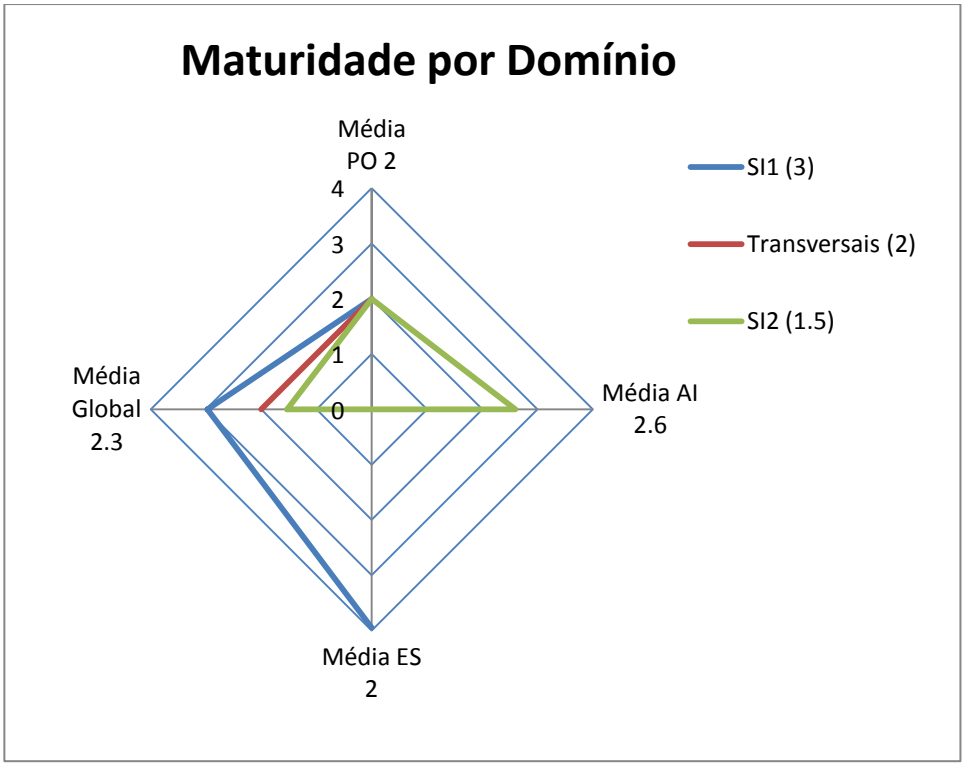


Figura 38 – Maturidade por domínio.

De seguida, na figura 39, apresenta-se o gráfico que ilustra a maturidade por processo.

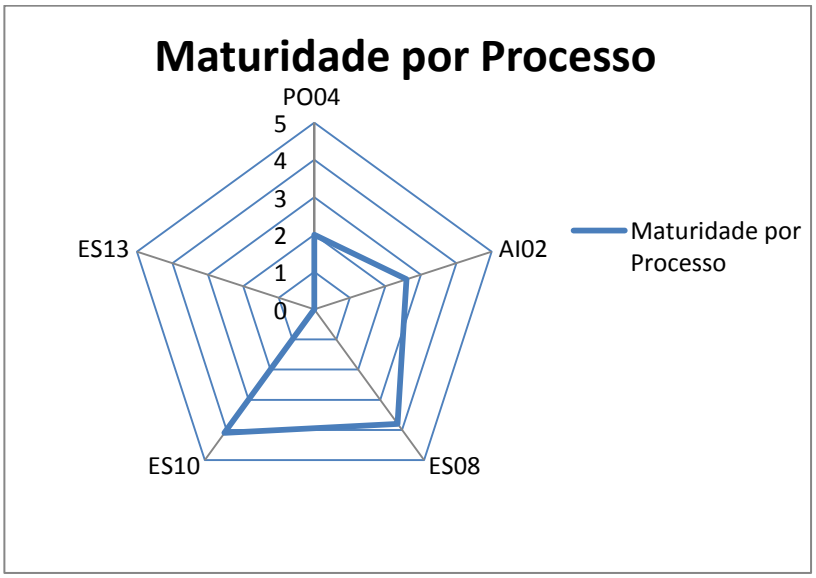


Figura 39 – Maturidade por processo.

Para o processo ES13 não foi recebida qualquer evidência pelo que a classificação foi 0. A organização mostrou-se muito bem estruturada no que diz respeito aos processos ES08 e ES10, executando-os segundo as melhores práticas internacionais.

Os processos foram ainda classificados segundo 6 vectores de maturidade presentes na *framework* CobiT 4.1 e já descritos na secção 5.1.3

A figura 40 ilustra essa classificação segundo os 6 vectores de maturidade:

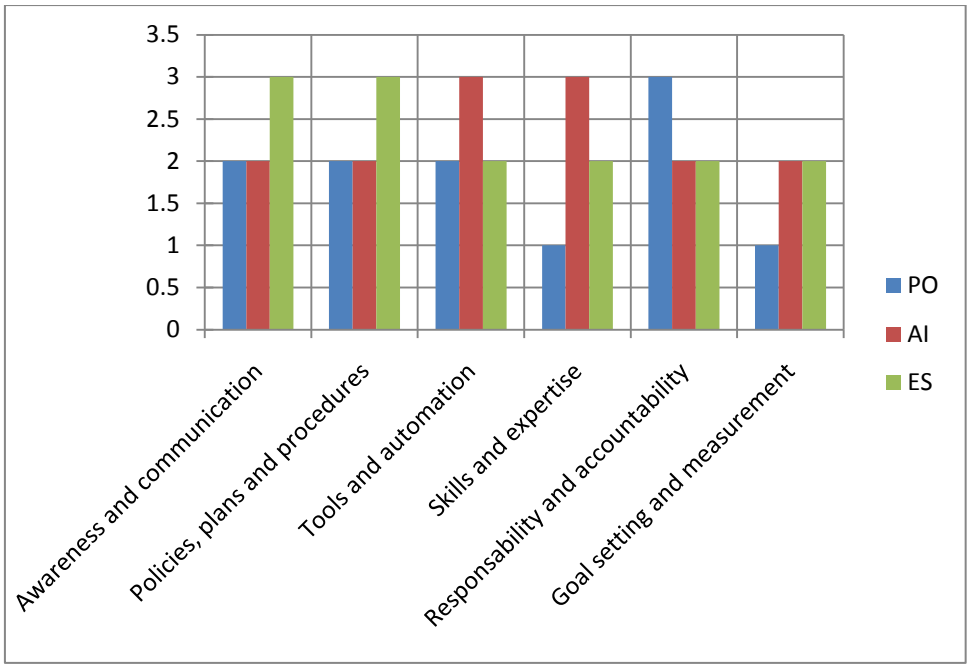


Figura 40 – Classificação segundos os seis vectores de maturidade.

5.2.4 Conclusão

A fase de conclusão consistiu na redacção de um relatório com toda a informação resultante da auditoria, tal como para todas as restantes auditorias foi também incluído um conjunto de sugestões de melhoria. Foi notório que a organização não está ainda orientada a processos, estes são executados de modo informal e dependem do *know how* dos colaboradores chave.

5.3 Auditoria ao DI de Grande Dimensão

Na auditoria realizada ao DI de grande dimensão o autor foi inserido apenas na fase de execução, levando a que fossem recolhidas apenas as informações respectivas a essa fase. O resultado final foi de 3.2 na escala de 0 a 5 da *framework* CobiT 4.1. A tabela seguinte sumariza informações respectivas ao DI e aos resultados da auditoria realizada:

Orçamento TI	22 500 000
Duração da auditoria	1 Mês
Nº de colaboradores TIC	160
Nº de colaboradores total	209
Processos auditados	28
Processos Transversais	18
Processos Específicos	10

SI auditados	3
Estado real da GFI do DI	3.2 (0 – 5)
Percentagem de processos formais	100%

Tabela 4 – Informações do DI de dimensão grande

5.3.1 Execução

Ao contrário das auditorias realizadas aos DI de dimensões menores, o autor foi inserido numa equipa de auditoria interna apenas na fase de execução. O DI em questão possui uma gestão da função informática de grande qualidade, está completamente orientado a processos e possui, para cada processo implementado, um *owner* processual. Este facto simplificou bastante o processo de auditoria pois permitiu definir com clareza os interlocutores responsáveis pelos processos no âmbito da auditoria. A sua média global de avaliação foi de 3.2 valores. O domínio de monitorização e avaliação obteve a melhor classificação (3.8) o que realça a elevada maturidade da GFI neste DI.

Na figura 41 apresenta-se o gráfico que resume os resultados finais, por domínio, da auditoria efectuada ao DI de grande dimensão.

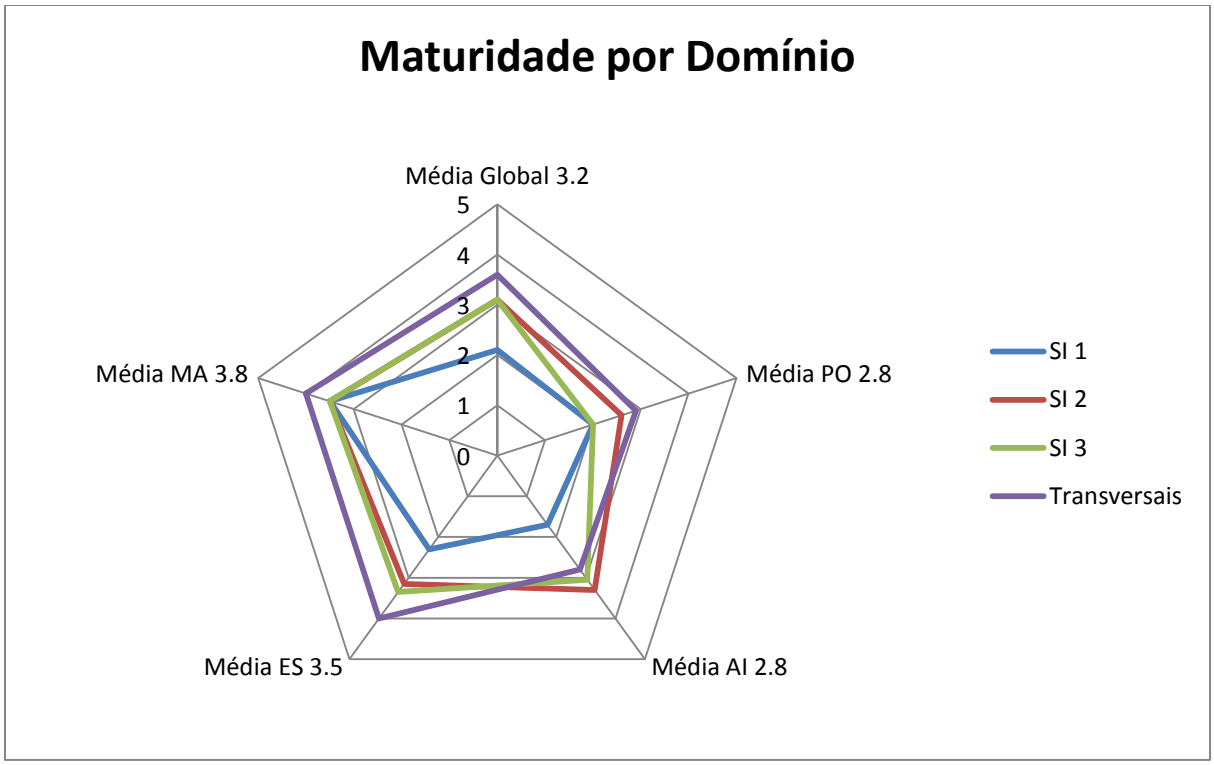


Figura 41 – Maturidade por domínio.

5.3.2 Conclusão

Nesta última fase foi produzido um relatório de conclusão da auditoria por alguns elementos da equipa onde constava um plano de acções de melhoria. O plano de acções contemplou, para cada

acção, o risco associado e o tempo médio de implementação. O processo de auditoria para além de ser efectuado com regularidade nesta organização é encarado como um mecanismo potencialmente benéfico para a qualidade dos serviços prestados. De referir ainda que a classificação obtida de 3.2 valores é, de facto, uma excelente classificação numa *framework* exigente como o CobiT 4.1.

5.4 Análise dos Resultados

Após apresentadas, de modo descritivo, as informações resultantes das 3 auditorias efectuadas pretende-se agora criticar e analisar o verdadeiro significado dos resultados anteriormente expressos. Estando o problema da tese focado principalmente nos DI de pequena dimensão, será dado especial enfoque a esse caso de estudo.

5.4.1 DI de pequena dimensão

Referindo a temática dos custos, se tivermos em conta o valor médio em TIC que deverá ser gasto por cada colaborador do OP, definido em 561 € anuais, então o orçamento deste DI está 255 mil euros acima do valor esperado. Contudo, como já referido pelos autores, este indicador pode não corresponder à realidade na medida em que o nº de cidadãos que usufruem dos SI disponibilizados pelo DI também deveria ser contabilizado.

Como se pode observar pela figura 32, o único processo em regime de *outsourcing* no DI de pequena dimensão (ES8 – Manage Service Desk and Incidents) foi o que obteve melhor classificação (0.6). Este facto vem comprovar que, em determinados contextos, a prática de outsourcing pode ser bastante vantajosa (Wonseok Oh, Faculty of Management, McGill University, 2005). Neste caso em específico, o DI conseguiu aumentar a qualidade dos serviços prestados no *Service Desk* e gestão de incidentes enquanto libertou recursos preciosos às actividades directamente relacionadas com o seu *core business*.

Durante o processo de auditoria foi notório que o CIO e os colaboradores do DI não tinha uma noção correcta de qual o estado da GFI no seu DI, nem possuíam os conhecimentos necessários para desenvolver um plano estratégico de TI que pudesse de certa forma direccionar o seu desenvolvimento.

- No questionário de alto nível (Fig. 28) indicou estar no nível 1 de maturidade, com muita probabilidade de avançar para o nível 2. Indicou também probabilidades altas de se situar nos níveis superiores, e.g., 40% para o nível 5.
- Para os 3 domínios avaliados indicou uma média de nível de maturidade de 2.0.
- Nas maturidades esperadas a curto prazo (12 meses), indicou, para vários processos, aumentos de 3 valores na escala de maturidade o que se revela impraticável em tempo tão reduzido.
- O CIO indicou que 25% dos processos CobiT estavam implementados de modo formal, i.e., completamente documentados. No entanto, durante a auditoria verificou-se que não

existe qualquer processo formal implementado. A organização não se encontra orientada a processos.

O nível de maturidade final atribuído ao DI de pequena dimensão foi 0 na escala de 0 a 5 da *framework* CobiT 4.1. Mas, o que é que significa, em termos de ineficiências/desvantagens, esta classificação tão reduzida?

- Não existe um plano estratégico definido para as TI:
  - A definição dos objectivos de TI em termos de benefícios esperados, performance e eficiência dos serviços prestados ao negócio não é efectuada aumentando assim a probabilidade de o DI incorrer numa situação de monopólio (Silva & Martins, 2008);
- Grande dependência por parte da organização nos colaboradores chave. Muito do conhecimento organizacional essencial ao negócio não é gerido de maneira adequada. Assim, caso um dos colaboradores termine as suas funções parte do conhecimento organizacional será perdido;
- Inexistência de economias de escala. Pela inexistência de *framework*s de GFI, e.g., de desenvolvimento de *software* ou de GSI, o nível de produtividade aumentará sempre a par dos custos adicionais de produção;
- Grande dificuldade na gestão da capacidade. Incapacidade na resposta a picos no pedido de serviços, pacotes aplicacionais, novas estruturas tecnológicas, etc. Dificuldade na satisfação dos requisitos de negócio;
- Mau desempenho na Identificação de requisitos de serviço, no acordo desses níveis de serviço e na monitorização do seu cumprimento;
- A organização não possui os seus processos, estruturas organizacionais e relacionamentos definidos;
- Não é efectuada uma gestão correcta dos investimentos em TI:
  - Não existe um portefólio actualizado de programas de investimento de TI;
  - Não são realizadas análises de custos benefício que possam prioritizar os investimentos em TI;
  - O portefólio não está alinhado com os planos estratégicos e tácticos de TI;
  - Não existe um procedimento de recolha de dados da execução orçamental de TI e a respectiva identificação de desvios;
- Não existe qualquer avaliação ou gestão de riscos:
  - Não existe uma abordagem integrada de avaliação de riscos de negócio e de TI;
  - A definição do contexto de risco não é efectuada;
  - Os eventos de risco não são identificados;
  - Não existem estratégias definidas de resposta a riscos.

Todos os pontos mencionados anteriormente correspondem a informações recolhidas durante a auditoria.

Verificou-se que a informática praticada neste DI não é gerida de modo adequado, a inexistência de um plano estratégico para as TI é um dos principais causadores do seu actual estado de

maturidade. O reduzido número de colaboradores impossibilita a realização de todas as actividades diárias e posterior monitorização com o nível de qualidade adequado.

5.4.2 DI de dimensão média

O nível de maturidade final atribuído ao DI de dimensão média foi 2 na escala de 0 a 5 da *framework* CobiT 4.1. A organização revelou algum conhecimento das melhores práticas internacionais no domínio da GFI e provou, em alguns casos, a sua implementação efectiva. Pela sua dimensão de 26 colaboradores demonstra já alguma capacidade em atingir economias de escala e conhecimento nos serviços que presta assim como garantir a sua qualidade. Existe também uma prática de atribuição de responsabilidades informal. Segundo os seis vectores de maturidade presentes na *framework* CobiT, este DI ficou classificado do seguinte modo:

- **Awareness and Communication** – A gestão comunica apenas as questões genéricas. Existe a consciência da necessidade de agir e evoluir neste vector de avaliação.
- **Policies, Plans and Procedures** – Existem processos comuns devido aos *skills* individuais mas são baseados na intuição dos colaboradores. Alguns aspectos dos processos são efectuados de modo repetitivo, podendo existir alguma documentação informal.
- **Tools and Automation** – Existe o uso de ferramentas baseadas em soluções desenvolvidas por colaboradores chave ou adquiridas no mercado.
- **Skills and Expertise** – As competências requeridas para as diferentes áreas são identificadas. Não existe um plano de formação, ao invés, a formação é fornecida quando surge uma necessidade específica.
- **Responsability and Accountability** – Os colaboradores assumem responsabilidades e são responsabilizados de modo informal. Existe alguma confusão na temática das responsabilidades quando surgem complicações.
- **Goal Setting and Measurement** – Ocorre a definição de alguns objectivos. Existe uma monitorização inconsistente e praticada apenas em áreas isoladas.

5.4.3 DI de grande dimensão

O nível de maturidade final atribuído ao DI de dimensão média foi 3 na escala de 0 a 5 da *framework* CobiT 4.1. O DI revelou um grande conhecimento de várias *framework*s no domínio das TI, tais como o CobiT e ITIL. Salientam-se as seguintes observações:

- Globalmente os processos estão definidos de forma transversal e aplicam-se uniformemente, quer nos controlos gerais, quer ao nível da sua aplicação nos subsistemas analisados.
- Os processos encontram-se bem definidos, implementados e comunicados a toda a organização.
- Cada processo possui um responsável.

- Existem práticas eficientes de monitorização da função informática. O que revela uma preocupação constante com o ciclo de melhoria contínua.
- Estão implementadas *frameworks* formais que servem como suporte à gestão da função informática tanto a nível de desenvolvimento como de monitorização ou, até mesmo de gestão de risco.

Segundo os seis vectores de maturidade presentes na *framework* CobiT, este DI ficou classificado do seguinte modo:

- **Awareness and Communication** – A gestão efectua toda a sua comunicação organizacional de modo formal e estruturado.
- **Policies, Plans and Procedures** – Existe uso de boas práticas. Os processos, políticas e procedimentos são definidos e documentados para todas as actividades chave.
- **Tools and Automation** – Os processos encontram-se automatizados através de ferramentas adequadas. No entanto algumas das ferramentas podem não estar totalmente integradas.
- **Skills and Expertise** – As competências requeridas para as diferentes áreas são actualizadas periodicamente. A formação é assegurada para todas as áreas.
- **Responsability and Accountability** – A responsabilidade por processo encontra-se definida, existem proprietários dos processos. No entanto, o proprietário do processo pode não ter total autoridade para exercer as suas responsabilidades.
- **Goal Setting and Measurement** – São definidos objectivos e métricas claramente comunicados e mapeados para os objectivos de negócio. Existem processos de monitorização e avaliação.

6 Aprendizagens Adquiridas

Com os dados apresentados e criticados na secção 5 valida-se a hipótese lançada na secção 3:

- Os DI de pequena dimensão existentes na APP têm uma baixa maturidade e má qualidade nos serviços que prestam.
    - Existe uma falta de conhecimento acentuada das melhores práticas internacionais na APP, com especial enfoque nos DI de pequena dimensão.
    - O nível de maturidade está, por norma, directamente relacionado com a dimensão do DI e com a qualidade dos serviços prestados.

O DI de pequena dimensão auditado obteve a classificação de 0 na escala de 0 a 5 da *framework* CobiT 4.1. Sabendo que o DI de pequena dimensão auditado representava a média daquilo que é esse tipo de DI na APP, e que está provado que a qualidade dos serviços prestados aumenta com a maturidade da organização (Cumps, Viaene, & Dedene, 2006), valida-se a hipótese.

Verificou-se, tendo em conta as classificações obtidas, que o nível de maturidade está directamente relacionado com a dimensão do DI e com a qualidade dos serviços prestados. Com o aumento do nível de maturidade é notória uma maior facilidade em alcançar economias de escala e um aumento na qualidade dos serviços. A relação custos/dimensão de clientes sai assim beneficiada, servindo-se mais clientes, com uma melhor qualidade de serviço e conseguindo ao mesmo tempo custos reduzidos por serviço. O DI de grande dimensão é um exemplo, serve cerca de 10 milhões de clientes indirectos com um orçamento de 22 milhões de euros**.**

Estamos perante um problema complexo, dispendioso e com vida própria. Está na altura de tomar iniciativas que combatam este tipo de erros na organização e gestão da função informática na APP. Se fizermos uma analogia com o sistema de ensino em Portugal, equiparando um DI a uma escola de ensino parece que o Governo já encontrou a solução: fechar todas as escolas com menos de 20 alunos como forma de reduzir custos, combater o insucesso escolar e apostar em novas escolas integradas (Jornal de Notícias, 2010). Ou, leia-se antes, encerrar todos os DI com menos de "x" colaboradores para combater o insucesso na GFI e apostar em novos DI integrados, capazes de obter economias de escala / conhecimento e de evoluir com mais facilidade. Esta analogia é de facto válida se tivermos em conta os seguintes factos:

- As escolas prestam serviços tal como os DI;
- Existem custos acrescidos associados à falta de economias de escala /conhecimento tanto nos DI como nas escolas;
- Existem custos desnecessários relacionados com as infra-estruturas em ambos os casos.

Os DI de pequena dimensão existentes na APP, por todos os factos mencionados anteriormente, têm dificuldade em justificar a sua existência enquanto entidades autónomas. É necessário promover a criação de DI partilhados na APP, capazes de servir uma quantidade considerável de OP com o

objectivo de obter reduções de custos e aumentos na qualidade dos serviços prestados. Os DI de pequena dimensão deverão ser exterminados a longo prazo, mantendo apenas aqueles que consigam evoluir o seu nível de maturidade e cuja dimensão / número de serviços prestados o justifique. Por todas as desvantagens que os DI de pequena dimensão trazem, já referidas na secção 1, e através da hipótese validada nesta investigação, pode-se afirmar que a relação entre os custos existentes na APP relativamente às TIC e o número de DI de pequena dimensão é expresso pelo gráfico seguinte:

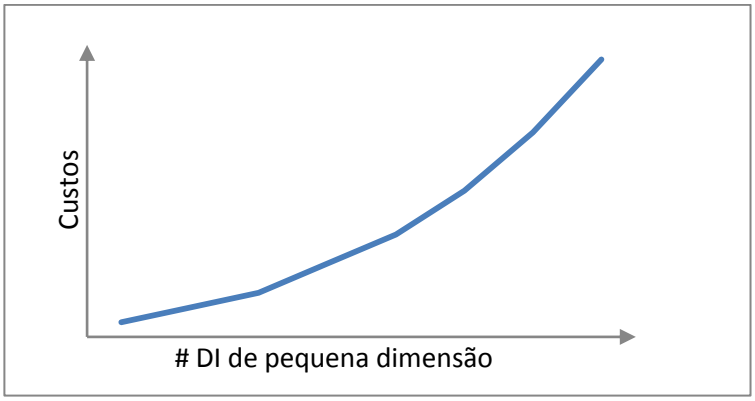


Figura 42 – Relação custos e nº de DI de pequena dimensão.

Voltando ao gráfico inicial apresentado na secção 3, podemos agora preenchê-lo com as classificações obtidas.

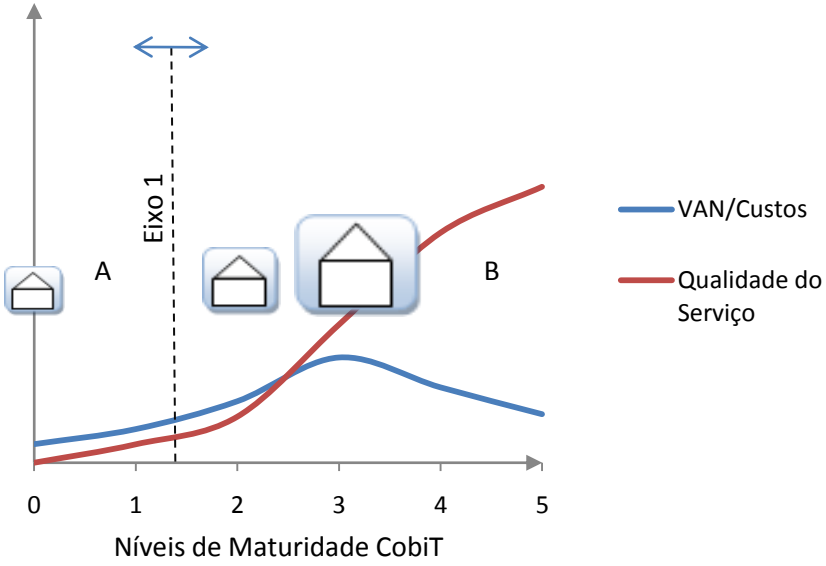


Figura 43 – Relação Maturidade Qualidade dos Serviços prestados

A fraca pontuação obtida pelos DI de pequena dimensão verificou-se ser consequência directa da falta de aplicação das melhores práticas no domínio da GSI através de *frameworks* como o ITIL, CobiT ou CMMI-SVC. Mas se a aplicação correcta deste tipo de *frameworks* está positivamente

relacionada com o desempenho e qualidade dos serviços prestados (Cumps, Viaene, & Dedene, 2006) qual será a principal razão para a não adopção destas práticas neste tipo de DI? Os DI de pequena dimensão não têm uma estrutura capaz de suportar os gastos e recursos necessários à implementação de *frameworks* deste género. O nível de formalização de processos e actividades ou até mesmo os custos de implementação que estas *framework*s pressupõem só se justificam em organizações com uma dimensão grande e que prestam um número considerável de serviços. Caso contrário, ao não conseguirem atingir economias de escala, os DI de pequena dimensão ficarão sem recursos para executar com sucesso o seu *core business*.

Através da figura 43 é perceptível o destaque negativo que o DI de pequena dimensão demonstra relativamente à classificação de maturidade. Apesar de a posição do eixo 1 não estar definida, é notório que os DI de pequena dimensão, tendo em conta os seus custos, qualidade do serviço e nível de maturidade, não justificam a sua existência enquanto entidades autónomas.

7 Conclusão

A Gestão da Função Informática (GFI) praticada na Administração Publica Portuguesa (APP) carece de intervenções urgentes e capazes de promover um modelo adequado à realidade actual, em que se insere a sociedade Portuguesa (Tavares, 2004) (Santos, 1996). É necessário alterar a postura da APP face aos novos padrões de exigência que a sociedade de informação pressupõe criando assim uma nova cultura organizacional cuja preocupação central seja o cliente, entenda-se, o cidadão. É fundamental eliminar a dispersão da função informática, aumentar a qualidade dos serviços fornecidos e diminuir o custo associado às TIC.

As *frameworks* de Gestão de Serviços Informáticos (GSI) representam, neste contexto, metodologias válidas e com grande credibilidade no mercado internacional capazes de evidenciar o problema da GFI e credibilizar todo o processo de modernização administrativa. Em particular, o uso da *framework* CobiT, como ferramenta de auditoria e recorrendo aos seus modelos de maturidade, permite uma comparação válida entre os diferentes tipos de DI, explicitando as suas vantagens e desvantagens.

No decorrer desta investigação foram avaliados três DI com o objectivo de avaliar a qualidade da função informática na APP. O DI de pequena dimensão, com a avaliação de 0.1 demonstrou um completo desconhecimento das melhores práticas internacionais. Verificou-se que, tendo em conta os resultados obtidos, o nível de maturidade está directamente relacionado com a dimensão do DI e com a qualidade dos serviços prestados. No entanto, apesar da falta de aplicação de *framework*s de GSI e da falta de liderança ou competências dos colaboradores, incluindo o CIO, a origem deste problema encontra-se a um nível mais abstracto, reside no próprio conceito deste tipo de DI. Os DI de pequena dimensão não têm uma estrutura capaz de suportar os gastos e recursos necessários à prestação de serviços com qualidade ou mesmo para evoluírem e acompanharem as necessidades do negócio. O esforço organizacional requerido à prestação de serviços com qualidade e de acordo com as melhores práticas internacionais só se justifica em organizações com uma dimensão grande e que prestam um número considerável de serviços.

Os custos acrescidos com a sucessiva criação e manutenção deste tipo de DI na APP são motivo suficiente para elevar esta problemática a outro patamar. Nos EUA, este é um problema que já originou mega projectos de centralização das TI. Mencionado na secção 2.3.1, está um exemplo de sucesso deste tipo de projectos numa organização que serve 7.8 Milhões de clientes e que possui um orçamento de 35 mil milhões de dólares. Estes números desmistificam a impossibilidade de realizar operações deste género na APP, mesmo incidindo nos grandes OP.

7.1 Principais Contribuições

Como principal contribuição destaca-se o facto de ter sido produzida informação válida e baseada numa *framework* credível sobre o estado da função informática na APP. A temática da organização da função informática está muito pouco aprofundada pelo que esta investigação veio enriquecer as informações relacionadas com este domínio, no âmbito da APP. Enumeram-se, de seguida, as contribuições alcançadas:

- Comparação e classificação de três *framework*s no domínio da gestão de serviços informáticos – ITIL V3, CobiT 4.1 e CMMI-SVC;
- Produção de informação válida e credível, baseada na *framework* CobiT 4.1, sobre o estado da função informática na APP;
- Validação da hipótese de que o nível de maturidade está directamente relacionado com a dimensão do DI e com a qualidade dos serviços prestados;
- Provou-se que existe uma falta de conhecimento acentuado das melhores práticas internacionais na APP, com especial enfoque nos DI de pequena dimensão;
- Definição de uma metodologia de solução baseada na *framework* CobiT 4.1 e posterior aplicação em três experiências, permitindo assim validar a hipótese proposta;
- Produção dos três relatórios de auditoria com a identificação dos pontos fortes e fracos nos 3 DI auditados. Estes relatórios contemplaram um conjunto de sugestões de melhoria para o aumento do nível de maturidade de cada DI auditado.

7.2 Principais Limitações

Como principal limitação desta investigação está o número reduzido de DI auditados por dimensão, apenas um. Apesar de cada DI a auditar ter sido escolhido tendo em conta que representava a média daquilo que é a realidade da APP nas três dimensões, grande, médio e pequeno, o número reduzido de DI pode de alguma forma descredibilizar esta investigação. Passo a enumerar as restantes limitações identificadas na execução desta investigação:

- A inexistência de uma *framework* que pudesse padronizar o processo de auditoria e de certo modo remover alguma da subjectividade que lhe está inerente, assim como facilitar a sua execução;
- A impossibilidade em estabelecer um número de processos fixo a auditar para cada DI devido à falta de recursos (tempo e disponibilidade dos interlocutores) e às restrições impostas pelas organizações;
- O número reduzido de informações existentes na fase inicial desta investigação, acerca da função informática na APP, condicionou a evolução da mesma;
- O facto de não ser possível quantificar o nº de clientes ou de serviços prestados por cada DI dificultou a comparação com foco no rácio custos/valor acrescido ao negócio e custos/dimensão.

7.3 Trabalho Futuro

Como trabalho futuro seria expectável auditar um número considerável de DI de pequena dimensão, a fim de aprofundar e quantificar melhor o problema existente. Assim, seria possível estender o campo de aplicação desta pesquisa e, por exemplo, calcular com alguma precisão a posição do eixo 1 definido na figura 43. Ou seja, determinar o nível mínimo de maturidade que justifique a existência de um DI. A produção de uma plataforma de auditoria que tornasse este processo mais consistente e que de certo modo automatizasse parte das análises manuais seria uma

mais-valia para o domínio das auditorias. Por fim, o desenvolvimento de um estudo que pudesse quantificar e dimensionar as reduções de custos realmente alcançáveis com projectos de centralização na APP poderia materializar os verdadeiros impactos desta investigação.

8 Referências

AMA. (2009). Obtido em 4 de 11 de 2009, de AMA: http://www.ama.pt

Amaral, L., & Varajão, J. (2007). *Planeamento de Sistemas de Informação.* Portugal: FCA.

Baxter, P., & Jack, S. (2008). Qualitative Case Study Methodology: Study Design and Implementation for Novice Researchers. *The Qualitative Report* , 531-543.

Brown, C., & Magill, S. (1994). Alignment of the IS Functions With the Enterprise: Toward a Model of Antecedents. *MIS Quarter , 18*, 371-403.

Brynjolfsson, E., & Hitt, L. (2000). Beyond Computation: Information Technology, Organizational Transformation and Business Performance. *Journal of Economic Perspectives , 14*, 23-48.

Coimbra, G., & Spinola, M. (9 de 2009). ICT Benchmark 2009: Principais Indicadores por Sector Económico. *Apresentação* . Lisboa, Portugal: IDC.

Cruz, F. (2008). Metodologia de Gestão de Serviços de IT: Uma abordagem orientada à reengenharia do ITIL. *Tese de Mestrado* .

Cumps, B., Viaene, S., & Dedene, G. (2006). Managing for Better Business-IT Alignment. *8*, 17-24.

Estrutura Matricial - AMA. (2010). Obtido em 22 de 04 de 2010, de Agência para a Modernização Administrativa: http://www.ama.pt/index.php?option=com_content&task=category&sectionid=1&id=74&Itemid=65

Gallagher, K. P., & Worrel, J. L. (2008). Organizing IT to promote agility. *Information Technology and Management* , 71-88.

Gray, R. (23 de 4 de 2007). ISO20000 itSMF.

Harno, K., Ruotsalainen, P., Nykänen, P., & Kopra, K. (2008). Migration from Regional to a National eHealth Network. *Second International Conference on the Digital Society*, (pp. 107-110). Sainte Luce.

Hochstein, A., Zarnekow, R., & Brenner, W. (2005). ITIL as Common Practice Reference Model for IT Service Management: Formal Assessment and Implications for Practice. *Proceedings of the 2005 IEEE International Conference on e-Technology, e-Commerce and e-Service (EEE'05) on e-Technology, e-Commerce and e-Service*, (pp. 704-710).

IDC. (2010). *Despesa TIC na Administração Pública num Ambiente Recessivo e de Restrições Orçamentais.* Lisboa.

IDC. (2007). *IDC eGovernment Connection- Anuário TIC para os Sectores da Administração Pública, Saúde e Educação.* Lisboa.

IDC. (2010). *Novos desafios dos CIO em Portugal: A importância da Gestão e Optimização dos Processos de TI.* Lisboa: IDC.

Inspecção Geral de Finanças. (2010). *Caracterização da despesa em Tecnologias da Informação e Comunicação na Administração Pública - Estratégia, Riscos e Mercados.*

ISACA. (2009). *Audit Process*. Obtido em 28 de 11 de 2009, de Web site de ISACA: http://www.isaca.org/Content/NavigationMenu/Students_and_Educators/IT_Audit_Basics/Audit_Process.htm

ITGI. (2007). *Assurance Guide using CobiT.* ITGI.

ITGI. (2007). *CobiT Quickstart.* ITGI.

ITGI. (2007). *Framework COBIT 4.1.*

ITGI;OGC. (2008). *Aligning CobiT 4.1, ITIL V3 and ISO/IEC 27002 for business Benefit.*

itSMF. (2009). *itSMF Portugal*. Obtido em 28 de 11 de 2009, de Web site de itSMF: http://www.itsmf.pt/

Jornal de Notícias. (5 de Junho de 2010). *Nacional.* Obtido em 22 de 06 de 2010, de Jornal de Notícias: http://jn.sapo.pt/PaginaInicial/Nacional/Interior.aspx?content_id=1586468

Mutsaers, E., Zee, H., & Giertz, H. (1997). The Evolution of Information Technology. *Information Management & Computer Security , 6*, 115-126.

OGC. (2007). *ITIL V3 - Continual Service Improvement.*

OGC. (2007). *ITIL V3 - Service Design.*

OGC. (2007). *ITIL V3 - Service Operation.*

OGC. (2007). *ITIL V3 - Service Strategy.*

OGC. (2007). *ITIL V3 - Service Transition.*

Oliveira, P. (2009). The Value of IITL. *Tese de Mestrado* .

Peterson, R., O'Callahan, R., & Ribers, P. (2000). Information Technology governance by design: investigating hybrid configurations and integration mechanisms. *Proceedings of the twenty first international conference on Information systems*, (pp. 435 - 452). Australia.

Ridley, G., Young, J., & Carrol, P. (2004). COBIT and its Utilization: A framework from the literature. *Proceedings of the 37th Hawaii International Conference on System Sciences*, (pp. Track 8, p.80233).

Rocha, A., & Vasconcelos, J. (2004). Os Modelos de Maturidade na Gestão de Sistemas de Informação. *Revista da Faculdade de Ciência e Tecnologia da Universidade Fernando Pessoa* , 93-107.

Romero, C. (2000). As TIC na Administração Pública. *Apresentação* . Lisboa, Portugal.

Sahibudin, S., Sharifi, M., & Ayat, M. Combining ITIL, COBIT and ISO/IEC 27002 in order to Design a comprehensive IT Framework in Organizations. *Second Asia International Conference on Modelling & Simulation*, (pp. 749-753).

Sambamurthy, V., & Zmud, R. W. (1999). Arrangements for Information Technology Governance: A Theory of Multiple Contingencies. *MIS Quarterly, Vol. 23, No. 2* , 261-290.

Santos, M. (1996). Padrão de Evolução da Função SI nos Serviços de Informática de Grande Dimensão da Administração Pública Portuguesa. *Tese de Mestrado* . Minho, Portugal.

SEI. (2009). *CMMI for Services V1.2.*

Silva, M. M., & Martins, J. S. (2008). *IT Governance: A Gestão da Informática.* Lisboa: FCA.

Soh, C., & Siong, N. (1995). *Citibank Asia Pacific: Managing Information Technology Consolidation, Change, and New Chanllenges.*

Tavares, J. (2004). Informação & Informática. Lisboa, Portugal.

Taylor, S., Iqbal, M., & Nieves, M. (2006). ITIL Service Strategy. The Stationary Office.

Tinto, M. (2010). Partilhar Serviços na Era do Cloud Computing. *Apresentação* . Lisboa.

Vliet, H., & Niessink, F. (1998). Toward Mature IT Services. *Journal of Software Process - Improvement and Practice* , 55-71.

Walters, J. (2009). Transforming Information Technology at the Department of Veterans Affairs. *Case Study* . IBM Center for The Business of Government.

Wonseok Oh, Faculty of Management, McGill University. (2005). Why Do Some Firms Outsource IT More Aggressively Than Others? The Effects of Organizational Characteristics on IT Outsourcing Decisions. *Proceedings of the Proceedings of the 38th Annual Hawaii International Conference on System Sciences*, (p. 259.3).

9 Anexos

9.1 **Anexo I –** Análise de risco alto nível CobiT 4.1

Risco			Quem o faz?						
Importância	Performance	**Importância** = Quão importante é para a organização numa escala de 1 (irrelevante) até 5 (muito) **Performance** = Quão bem feito é de 1 (muito bem) até 5 (não se sabe ou é muito mal) **Formalidade** = Existência de um contracto, SLA ou um procedimento claramente documentado (**S**im, **N**ão ou **?**) **Auditado** = **S**im, **N**ão ou **?** **Accountable** = Nome ou 'não se sabe' Domínios do COBIT's e Processos	TI	Outro	Outsourcing	Não se sabe	Auditado	Formalidade	Quem é accountable?
		Planear e Organizar							
		PO1 Definir um plano estratégico de TI.							
		PO2 Definir a Arquitectura da Informação.							
		PO3 Determinar o Direcionamento Tecnológico.							
		PO4 Definir os Processos, Organização e os Relacionamentos de TI.							
		PO5 Gerir o Investimento de TI.							
		PO6 Comunicar as Diretrizes e Expectativas da Gestão.							
		PO7 Gerir os Recursos Humanos de TI.							
		PO8 Gerir a qualidade.							
		PO9 Avaliar e Gerir os Riscos de TI.							
		PO10 Gerir Projectos.							
		Adquirir e Implementar							
		AI1 Identificar Soluções Automatizadas.							
		AI2 Adquirir e Manter Software Aplicativo.							
		AI3 Adquirir e Manter Infraestrutura de Tecnologia.							
		AI4 Habilitar Operação e Uso.							
		AI5 Adquirir Recursos de TI.							
		AI6 Gerir Mudanças.							
		AI7 Instalar e Homologar Soluções e Mudanças.							
		Entregar e Suportar							
		DS1 Definir e Gerenciar Níveis de Serviços.							
		DS2 Gerir Serviços de Terceiros.							
		DS3 Gerir Capacidade e Desempenho.							
		DS4 Assegurar Continuidade de Serviços.							

		DS5 Assegurar a Segurança dos Sistemas.							
		DS6 Identificar e Alocar Custos.							
		DS7 Educar e Treinar os Utilizadores.							
		DS8 Gerir o service desk e incidentes.							
		DS9 Gerir a Configuração.							
		DS10 Gerir Problemas.							
		DS11 Gerir os Dados.							
		DS12 Gerir o Ambiente Físico.							
		DS13 Gerir as Operações.							
		Monitorizar e Avaliar							
		ME1 Monitorizar e Avaliar o Desempenho.							
		ME2 Monitorizar e Avaliar os Contolos Internos.							
		ME3 Assegurar a Conformidade com Requisitos Externos.							
		ME4 Prover a Governança de TI.							

9.2 **Anexo II –** Análise de maturidade alto nível CobiT 4.1: Exemplo de aplicação ao processo PO1.

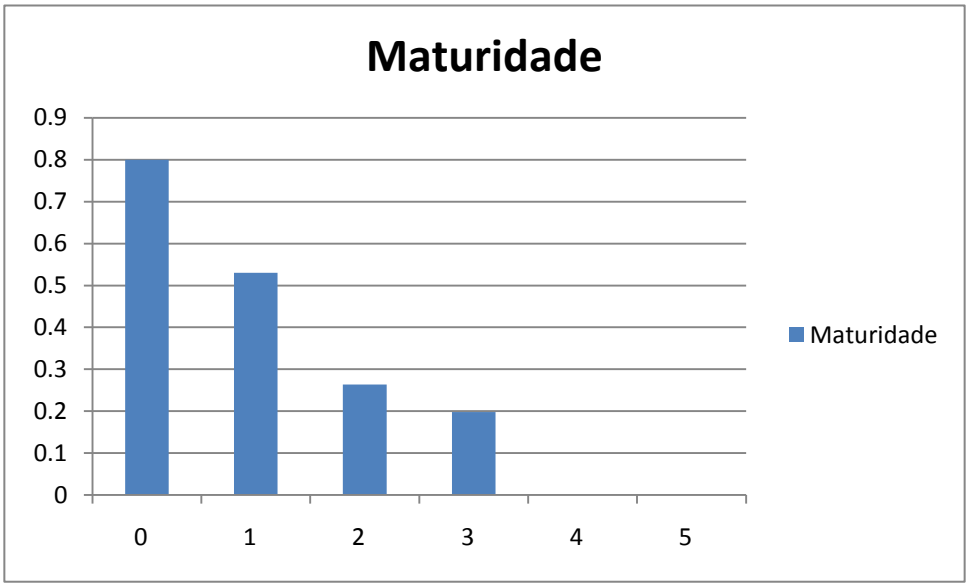
				Valor de Correspondência				
				0.00	0.33	0.66	1.00	
PID: PO1 **Nível de Maturidade:** 0				Nenhum	Pouco	Algum	Completamente	Valor
Nº	**Frase**		**Peso %**					
1	O plano estratégico de TI não é realizado.		80				x	**0.80**
2	A gestão não tem conhecimento que o plano é necessário para suportar os requisitos de negócio.		20	x				**0**
		Peso Total:	100%	**Correspondência:**				**0.80**

Questionário para o Processo de negócio com o identificador PO1 no nível de maturidade 0.

			Valor de Correspondência				
			0.00	0.33	0.66	1.00	
PID: PO1 **Nível de Maturidade:** 5			Nenhum	Pouco	Algum	Completamente	Valor
Nº	**Frase**	**Peso %**					
	O PETI é um processo documentado e constantemente actualizado.	25	X				**0**
	É continuamente considerado no estabelecimento de requisitos de negócio.	25	X				**0**
	O PETI traduz-se em valor de negócio acrescido nos investimentos de TI.	10	X				**0**
	São realizados e actualizados periodicamente planos realísticos de longo prazo para reflectir alterações tecnológicas e de negócio.	20	X				**0**
	As práticas internas do processo PETI são comparadas com as melhores práticas da indústria e consideram-se essas comparações na	10	X				**0**

	elaboração do PETI.							
	O PETI identifica a vantagem competitiva e novas capacidades de negócio que os desenvolvimento de tecnologia poderá implicar.		10	**x**				**0**
		Peso Total:	100%	**Correspondência:**				**0**

Questionário para o Processo de negócio com o identificador PO1 no nível de maturidade 5.



Resumo do questionário alto nível para os 6 níveis de maturidade. Neste Processo, a organização encontra-se claramente no nível 0 com alguma probabilidade de avançar para o nível 1.

9.3 **Anexo III –** Folha de controlo CobiT 4.1: Exemplo para os objectivos de controlo 2 e 3 do processo PO1 .

PO1.CO.2	Alinhamento TI-Negócio	- Assegurar que a gestão do negócio conhece e entende os serviços disponibilizados pelas TI e as capacidades potenciais; - Assegurar que a gestão de TI conhece e entende as directrizes do negócio; - Assegurar o alinhamento e comunicação entre a estratégia de negócio e de TI, associando claramente objectivos corporativos e objectivos de TI e reconhecendo oportunidades e limitações; e - Identificar criticamente as dependências de TI na estratégia corporativa e mediar os imperativos do negócio e de TI, para que as prioridades possam ser acordadas e definidas.	PO1.CO.2.AC.1	Existe um processo, comunicado e revisto periodicamente, que assegura a comunicação de oportunidades de negócio entre a gestão do negócio e das TI's.
			PO1.CO.2.AC.2	Existe um processo, comunicado e revisto periodicamente, que assegura a recolha do contributo da gestão de TI para a definição dos objectivos estratégicos da [Empresa].
PO1.CO.3	Avaliação da performance actual	- Assegurar a avaliação do desempenho de projectos e dos recursos de TI existentes, em termos de contribuição para os objectivos de negócios, funcionalidade, estabilidade, complexidade, custos, etc.	PO1.CO.3.AC.1	Existe um processo, comunicado e revisto periodicamente, que assegura a definição, avaliação e reporte de indicadores de performance da função de TI para a gestão de topo e áreas chave da [Empresa].
			PO1.CO.3.	Existe um processo periódico

			AC.2	de revisão da performance de TI por comparação com os objectivos definidos no plano operacional de TI.
			PO1.CO .3. AC.3	Existe um procedimento periódico de avaliação dos sistemas em termos da sua capacidade por comparação com as melhores práticas da industria e/ou sector de actividade.

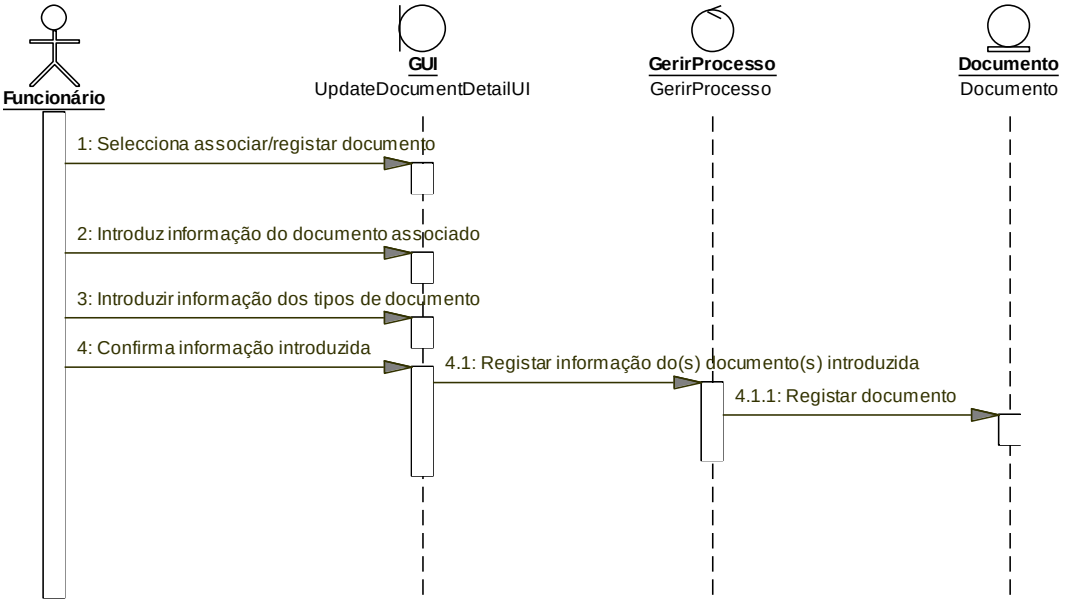
9.4 **Anexo IV –** Exemplo de evidência para a Actividade de Controlo AI2.CO1.AC1

Processo – Aquisição e Manutenção de Software Aplicacional.

Objectivo de Controlo – Modelo de desenho de alto nível.

Actividade de Controlo – Existe um modelo de desenho de alto nível que traduza os requisitos de negócio para o desenvolvimento de software.

Evidência:


Funcionário
GUI
UpdateDocumentDetailUI
GerirProcesso
GerirProcesso
Documento
Documento
1: Selecciona associar/registar documento
2: Introduz informação do documento associado
3: Introduzir informação dos tipos de documento
4: Confirma informação introduzida
4.1: Registar informação do(s) documento(s) introduzida
4.1.1: Registar documento